UNIDADES TECNOLÓGICAS DE SANTANDER · ÉTICA DEL HACKING / CIBERSEGURIDAD DEFENSIVA

Parcial práctico — Segundo corte · Informe técnico

Implementación de un SOC Nivel 1 para ERP Pyme Fácil S.A.S.

Caso C21 · Monitoreo, triage, documentación y escalamiento

Estudiantes	Juan Pérez y Juan Niño
Docente	Julian Barney Jaimes Rincon
Programa	Tecnología en Sistemas Informáticos / Ingeniería de Sistemas
Caso	C21 — ERP Pyme Fácil S.A.S. (implementación de ERP de código abierto)
Modalidad	En pareja · 2 semanas calendario
Versión	0.3 — 21 de octubre de 2026
Repositorio	soc-n1-c21-perez-nino (privado)

Todas las empresas, personas, dominios y direcciones de este documento son ficticios. Las pruebas se hicieron solo en máquinas virtuales propias en una red aislada.

Historial de versiones. 0.1 (20/10/2026): borrador documental de las Fases 0 a 8. 0.2 (21/10/2026): laboratorio real de Wazuh con FIM, reglas 100210–100212 y active response. **0.3 (21/10/2026, esta versión):** agente Windows activo, SCA 45 %, vulnerabilidades, desbloqueo automático y escenario 1 (CVE-2026-72422, falso positivo). 1.0 pendiente: Kaspersky, GLPI, cotizaciones y video.

Enlaces de la entrega. Repositorio privado `soc-n1-c21-perez-nino`: [pegar URL de GitHub] (agregar al docente como colaborador). Video no listado: [pegar URL de YouTube]. GLPI: `https://soporte.<dominio>` (la IP no se publica; solo durante la sustentación).

Estado del trabajo

Fase	Estado al 21/10/2026
0 — Alcance y ética	Completos; falta la firma de la carta
1 — Arquitectura	Diseño completo; laboratorio en 192.168.56.0/24
2 — Wazuh	**Completa en lo esencial:** 2 agentes activos, FIM, 3 reglas, active response con desbloqueo, SCA (45 %), vulnerabilidades y los 3 escenarios; faltan solo `wazuh-logtest` y el tablero
3 — Kaspersky · 4 — GLPI	Diseño y configuración definidos; instalación pendiente
5 — NGFW · 7 — Presupuesto	Requisitos, matriz, cronograma y RACI listos; cotizaciones reales pendientes
6 — Procesos	Manual, 9 playbooks, Anexo D y 3 alertas reales listos; registro en GLPI pendiente
8 — Documentación	Informe y guion listos; video pendiente

Contenido

1. Resumen ejecutivo

2. Caso y alcance

3. Arquitectura

4. SIEM Wazuh

5. EDR/XDR Kaspersky

6. GLPI en la nube

7. Firewall de nueva generación (NGFW)

8. Procesos del SOC N1

9. Presupuesto, cronograma y RACI

10. Conclusiones

Referencias

Anexos: A, B, H, C, D, E, F, G, I y guion del video

1. Resumen ejecutivo

ERP Pyme Fácil S.A.S. implementa ERP de código abierto para otras pymes y hoy no tiene SIEM, EDR centralizado ni mesa de tickets de seguridad. Su punto débil es claro: servidores de demostración publicados en Internet, a veces sin parches, y entornos de prueba donde terminan datos reales de clientes (contabilidad, nómina, terceros).

Se propone un SOC Nivel 1 híbrido: dos personas internas cubren el N1 de 7:00 a 19:00 y se turnan la guardia, y un proveedor externo actúa como N2 por demanda. La pila es Wazuh como SIEM todo en uno, Kaspersky Next EDR Foundations como EDR, GLPI en la nube para tickets e inventario y un NGFW de gama de entrada que se cotiza con tres fabricantes.

Lo implementado. En un laboratorio aislado de VirtualBox (red host-only 192.168.56.0/24) funcionan el servidor `wz-c21pn-01` con Wazuh 4.14 y dos agentes activos: `ub-c21pn-01` (Linux, representa el servidor del ERP) y `wc-c21pn-01` (Windows 10). **Los tres escenarios del caso quedaron demostrados con eventos reales:**

- **Cambio en la configuración del ERP (FIM):** al modificar `/etc/odoo/odoo.conf` se disparan la regla 550 y la personalizada 100210 en segundos (modo *realtime*).
- **Fuerza bruta SSH:** diez intentos con un usuario inexistente disparan 5712 y la personalizada 100212 (nivel 12). La respuesta activa bloqueó la IP de origen a las 03:47:10 UTC y la liberó sola a las 03:50:12 (182 s).
- **Vulnerabilidad crítica:** Wazuh reportó 242 críticas sobre el kernel; el triage del CVE-2026-72422 (CVSS 9.8) lo clasificó como **falso positivo** porque la versión instalada ya es la corregida y el componente vulnerable (ksmbd) no está activo. El análisis completo es el Anexo D.

Corrieron también el SCA (CIS Ubuntu 24.04, 45 %) y la detección de vulnerabilidades. Kaspersky, GLPI, el resto de los tickets y el video se ejecutan en la siguiente etapa; su diseño completo está en los capítulos 5, 6 y 8.

Costo. El caso tiene presupuesto Bajo: CAPEX ≤ COP 20 M y OPEX ≤ COP 1,5 M/mes. Wazuh y GLPI no pagan licencia, así que el dinero va al NGFW con suscripciones, las licencias de Kaspersky para 20 equipos, un servidor para el SIEM y el VPS de GLPI. El TCO a 3 años se calcula con las cotizaciones reales: **[PENDIENTE COTIZACIONES]**.

2. Caso y alcance

El SOC N1 cubre los 20 equipos de ERP Pyme Fácil, su red y sus servicios en la nube, con monitoreo activo de lunes a viernes de 7:00 a 19:00 y guardia por notificación para alertas críticas y altas.

2.1 La empresa en pocas palabras

ERP Pyme Fácil S.A.S. es una pyme bumanguesa (ficticia) de 10 personas que implanta ERP de código abierto en empresas pequeñas: parametriza contabilidad, nómina, inventarios y facturación electrónica, migra datos del cliente y da soporte posventa. Trabaja en modo híbrido: la mitad del equipo pasa buena parte de la semana en las instalaciones de los clientes.

Para vender, la empresa publica servidores de demostración en Internet donde el cliente prueba el ERP antes de firmar. Ahí está el problema: esos servidores se montan rápido, se parchean poco y a veces se cargan con copias reales de datos del cliente para que la demo "se vea de verdad". Eso convierte un servidor de vitrina en un activo con datos contables y de nómina de terceros.

Dato	Valor
Giro	Implementación de ERP de código abierto
Modalidad	Híbrida (oficina + clientes)
Madurez de seguridad	Baja

Dato	Valor
Presupuesto	Bajo: CAPEX ≤ COP 20 M · OPEX ≤ COP 1,5 M/mes
Riesgo particular	Datos reales de clientes en pruebas; servidores de demostración sin parchear
Escenarios del caso	1) Vulnerabilidad crítica (Wazuh) · 2) Fuerza bruta SSH contra staging (Wazuh) · 3) Cambio en el archivo de configuración del ERP (FIM, Wazuh)

2.2 Supuestos adicionales

Estos supuestos no cambian los datos del caso (10 empleados, 20 equipos, SO); solo completan lo que la ficha no dice.

1. El ERP es **Odoo Community** sobre Ubuntu Server con PostgreSQL y Nginx como proxy inverso. Su archivo de configuración crítico es `/etc/odoo/odoo.conf`.
2. Los 4 servidores están en la oficina (on-premises). El servidor de demostración y el de staging se publican a Internet a través del NGFW en una **DMZ** (VLAN 25) que se añade a las VLAN Oficina y Servidores de la topología sugerida.
3. El acceso SSH administrativo a staging hoy está abierto a Internet (por eso el escenario de fuerza bruta); el diseño lo cierra y lo deja solo por VPN.
4. El correo corporativo es un servicio en la nube (SaaS); su monitoreo es responsabilidad del proveedor y queda fuera del laboratorio.
5. GLPI corre en un VPS en la nube administrado por la empresa, en el dominio ficticio `soporte.erppymefacil.example`.
6. Dominio interno y de correo: `erppymefacil.example`. Direcciones públicas de documentación: `203.0.113.0/24`.
7. Todos los nombres de personas, correos e IP de este informe son ficticios.
8. Nomenclatura de hosts: `<TIPO>-C21PN-<NN>` en producción y `tipo-c21pn-NN` en el laboratorio (wz = Wazuh, ub = Ubuntu, wc = Windows cliente). C21 = caso, PN = Pérez y Niño.

2.3 Alcance

Aspecto	Incluido	Excluido
Activos	Los 20 equipos, NGFW, switch, 2 AP, VPS de GLPI	Sistemas de los clientes, equipos personales, correo SaaS (solo se documenta)
Ubicaciones	Oficina (Bucaramanga), portátiles en cliente vía VPN, VPS en la nube	Redes de los clientes
Horario de monitoreo	L–V 7:00–19:00 activo; guardia 24×7 para crítica y alta	Monitoreo activo nocturno de severidad media o baja
Actividades permitidas	Instalar y configurar herramientas en VM propias; EICAR; FIM; intentos fallidos de SSH entre VM propias	Escaneos o pruebas contra terceros, la UTS o Internet
Laboratorio	Red host-only `192.168.56.0/24` de VirtualBox, aislada	Red institucional y doméstica

2.4 Clasificación de la información

Nivel	Ejemplos en el caso	Tratamiento en el SOC
Pública	Sitio web, folletos, catálogo de servicios	Sin restricción
Interna	Procedimientos, playbooks, inventario sin IP	Solo personal de la empresa
Confidencial	Logs del SIEM, tickets, configuraciones, diagramas con IP	Acceso por perfil; retención definida; nunca fuera del SOC
Restringida	Datos contables y de nómina de clientes, respaldos, contraseñas, llaves	Cifrado, mínimo privilegio; jamás en tickets ni capturas (se citan por identificador)

Regla práctica para los tickets: el analista describe el evento (host, usuario, IP, regla), nunca pega registros con datos de clientes. Si una evidencia contiene datos personales, se guarda en el repositorio seguro de evidencias y en el ticket queda solo su referencia y hash.

2.5 Inventario de activos

El inventario completo de los 20 equipos, con propietario, VLAN, C/I/D, criticidad y agentes, está en el **Anexo A**; los equipos de red y servicios van aparte.

Tipo	Cantidad	Hostnames	SO	Criticidad
Estación de consultoría	8	PC-C21PN-01 a 08	Windows 11 Pro	2–3
Portátil de consultor en cliente	4	LT-C21PN-01 a 04	Windows 11 Pro	3
Portátil de gerencia	2	MAC-C21PN-01 y 02	macOS	3
Estación de desarrollo	2	DEV-C21PN-01 y 02	Ubuntu Desktop 24.04	3
Servidor (demo, BD, staging, respaldo)	4	SRV-C21PN-DEMO, DB, STG, BKP	Ubuntu Server 24.04	3
Red y servicios (fuera de los 20)	6	NGFW, switch, 2 AP, VPS GLPI, correo SaaS, DNS	—	2–3

2.6 Matriz de riesgos

La matriz completa tiene 13 riesgos y está en el **Anexo B** (nivel = probabilidad × impacto, escala 1–5). Los cinco más altos marcan las prioridades del SOC:

ID	Riesgo	Nivel	Control principal del SOC
R-01	Fuga de datos reales de clientes cargados en demo o staging sin enmascarar	20 Crítico	Política de datos enmascarados, FIM, PB-09 y PB-03
R-02	Explotación de un CVE crítico en el servidor de demostración expuesto	16 Alto	Vulnerability Detection de Wazuh, IPS del NGFW, PB-09
R-03	Acceso no autorizado por fuerza bruta SSH a staging	16 Alto	Regla 100212 + active response (probado), SSH solo por VPN, PB-01
R-04	Ransomware en estaciones que alcance el servidor de respaldos	15 Alto	EDR con prevención de comportamiento, respaldo fuera de línea, PB-02
R-05	Cambio no autorizado en `odoo.conf`	12 Alto	FIM realtime + reglas 100210/100211 (probado), PB-03

R-01 es el único riesgo crítico y sale directamente del riesgo particular del caso. El SOC no lo elimina por sí solo: la medida de fondo es la política de "cero datos reales en demo", y el SOC vigila que se cumpla.

2.7 Alcance del SOC N1

- **Cubre:** alertas de Wazuh, Kaspersky y el NGFW; reportes de usuarios por GLPI; triage, contención básica autorizada, documentación y escalamiento.
- **No cubre:** forense, análisis de malware, cambios de reglas sin aprobación, incidentes dentro de los sistemas de los clientes.
- **Horario:** activo L–V 7:00–19:00; guardia por notificación en noches, fines de semana y festivos (solo crítica y alta).
- **Metas iniciales (primer mes):** cobertura de agentes 100 % (20/20), las 3 reglas de los escenarios activas y probadas, ≥ 90 % de tickets dentro del SLA, cero CVE críticos abiertos más de 30 días en SRV-DEMO.

La carta de autorización y reglas de compromiso está en el Anexo H, al final del documento.

3. Arquitectura

La red se divide en siete VLAN para que la DMZ expuesta no tenga camino directo a la base de datos ni a los respaldos, y todos los eventos convergen en un Wazuh todo en uno ubicado en una VLAN de seguridad a la que solo entran los analistas.

3.1 Diagrama de red y flujo de logs

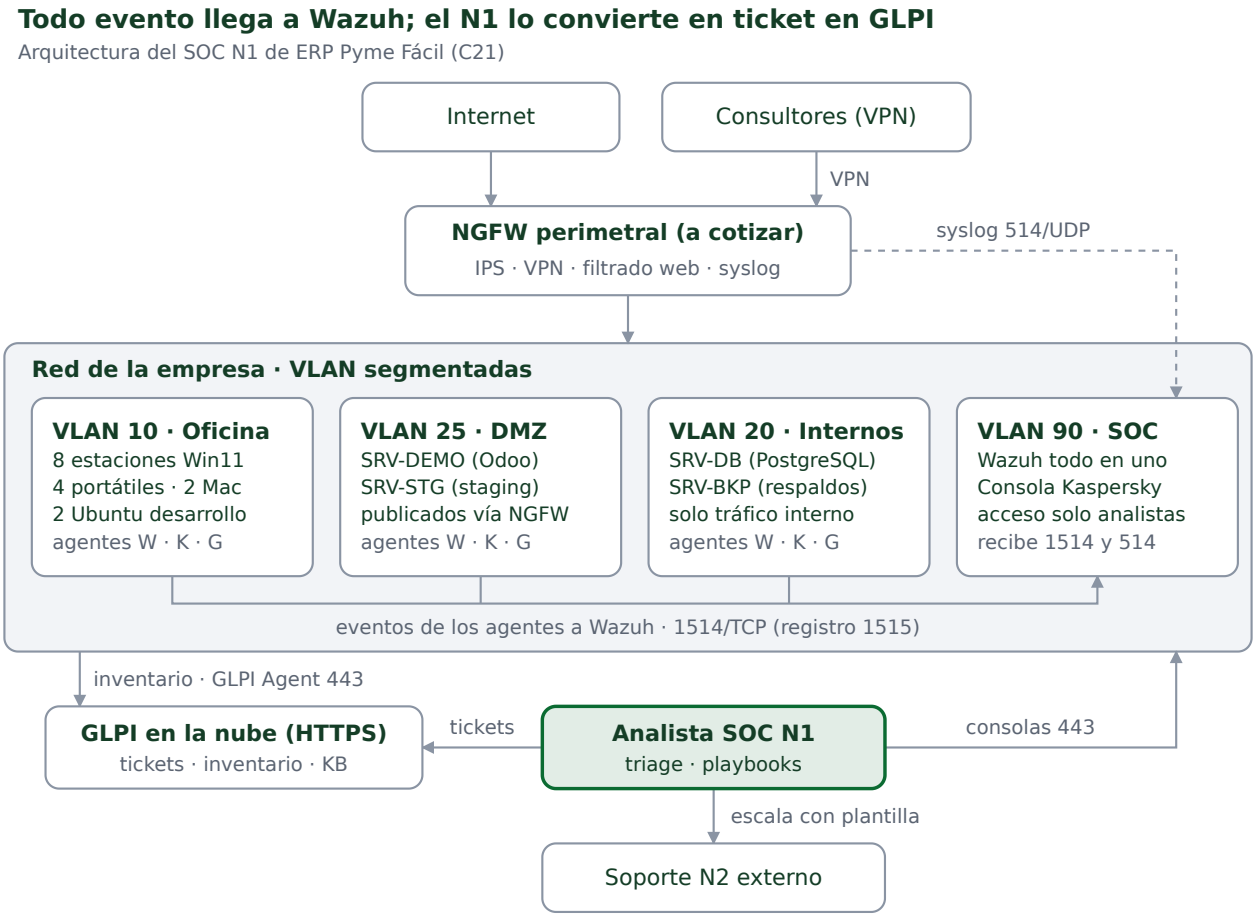


Diagrama 1. *Arquitectura de producción del SOC N1 de ERP Pyme Fácil: VLAN, flujos de eventos hacia Wazuh, tickets en GLPI y escalamiento a N2.*

El NGFW es el único punto de entrada: publica la demo y staging en la DMZ, termina la VPN de los consultores y envía su registro a Wazuh. El analista trabaja desde las consolas (Wazuh, Kaspersky) y registra todo en GLPI; lo que supera su rol lo escala a N2. El archivo editable (diagrams.net) y el PNG van en `01-arquitectura/` del repositorio.

3.2 Segmentación (VLAN)

VLAN	Uso	Subred	Reglas mínimas
10	Oficina: estaciones y portátiles	10.21.10.0/24	Salida a Internet filtrada (control web, IPS); hacia la DMZ solo HTTPS y SSH desde DEV y PC-07; sin acceso a VLAN 20
20	Servidores internos (BD, respaldos)	10.21.20.0/24	Sin salida a Internet salvo repositorios de paquetes; PostgreSQL 5432 solo desde la DMZ; SSH solo desde VLAN 99
25	DMZ: demo y staging	10.21.25.0/24	Desde Internet solo 443; SSH solo desde la VPN de administración; nunca inicia conexiones hacia VLAN 10
30	Invitados	10.21.30.0/24	Solo Internet; aislada de todas las VLAN
50	VPN de usuarios remotos	10.21.50.0/24	Mismo perfil que la VLAN 10 + MFA
90	Seguridad (Wazuh, consola Kaspersky)	10.21.90.0/24	Recibe 1514/1515 de agentes y 514 del NGFW; consolas solo desde PC-07 y PC-08
99	Gestión de red	10.21.99.0/24	Administración del NGFW, switch y AP; solo desde PC-07

Laboratorio. No se replica la numeración de producción. Todo vive en una red host-only de VirtualBox, `192.168.56.0/24`, sin salida a la red institucional: `wz-c21pn-01` (192.168.56.10, Wazuh), `ub-c21pn-01` (192.168.56.11, agente Linux que representa SRV-C21PN-STG) y `wc-c21pn-01` (192.168.56.12, cliente Windows, pendiente). El adaptador NAT de cada VM solo se usa para descargar paquetes. El detalle de recursos está en el cap. 4.1.

3.3 Flujos de logs y puertos

Origen	Destino	Puerto / protocolo	Qué viaja
Agentes Wazuh (20 equipos)	Wazuh manager	1514/TCP	Eventos, FIM, SCA, inventario de paquetes
Agentes Wazuh	Wazuh manager	1515/TCP	Registro (enrollment)
NGFW	Wazuh manager	514/UDP	Tráfico denegado, IPS, VPN, cambios de configuración
Consola Kaspersky	Wazuh manager	514/UDP (o TCP)	Detecciones y fallas en formato CEF
Network Agent (endpoints)	Consola Kaspersky	13000/TCP y 14000/TCP	Gestión del agente (verificar en la versión instalada)
Analista N1	Wazuh Dashboard	443/TCP	Consola del SIEM
Analista N1	Consola Kaspersky	13291/TCP o 8080/TCP (consola web)	Administración (verificar)
GLPI Agent (endpoints)	GLPI en la nube	443/TCP	Inventario
Analista N1 y usuarios	GLPI en la nube	443/TCP	Tickets y base de conocimiento
GLPI	Servidor SMTP del correo SaaS	587/TCP (STARTTLS)	Notificaciones
Todos los equipos	NGFW (servidor NTP interno)	123/UDP	Sincronización de hora
Consultores remotos	NGFW	Según el fabricante (IPsec 500/4500 UDP o SSL VPN 443)	Túnel VPN

3.4 Dimensionamiento

Con 20 equipos y un margen de crecimiento del 30 % se llega a 26 agentes, justo por encima del primer escalón de la guía rápida de Wazuh (1–25 agentes). Por eso producción se dimensiona en el segundo escalón y el laboratorio en el primero.

Componente	Laboratorio	Producción (20 agentes + 30 %)	Justificación
Wazuh todo en uno	4 vCPU, 8 GB RAM, 50 GB	8 vCPU, 16 GB RAM, 200 GB SSD	La guía oficial pide 8 vCPU, 8 GiB y 100 GB para 26–50 agentes y 90 días; se duplica RAM y disco por los logs del NGFW y el heap del indexer
Consola Kaspersky	VM Windows Server de prueba o consola en la nube	Consola en la nube (preferida)	Evita comprar licencia de Windows Server y hardware; decisión en el cap. 5
GLPI en la nube	2 vCPU, 4 GB, 40 GB	2 vCPU, 4 GB, 40 GB SSD + instantáneas	10 usuarios y 20 activos; sobra capacidad para adjuntos de 3 años
Respaldos	Instantánea de VM	SRV-BKP + copia externa semanal	Regla 3-2-1 adaptada al presupuesto

3.5 Servicios transversales

- **Hora:** NTP único servido por el NGFW (sincronizado con `pool.ntp.org` o el servidor del ISP); zona `America/Bogota` en todos los equipos, el SIEM y GLPI.
- **Nombres:** `<TIPO>-C21PN-<NN>` (PC, LT, MAC, DEV, SRV).

- **Retención:** 90 días en caliente en el indexer de Wazuh para búsqueda rápida y 12 meses archivados (comprimidos en SRV-BKP). Se eligen 12 meses porque los proyectos de implantación duran entre 3 y 9 meses y un incidente puede descubrirse cuando el cliente ya salió a producción.
- **Respaldos:** configuración de Wazuh (`/var/ossec/etc` , reglas y tableros) diaria; GLPI (base y archivos) diaria con 14 días de retención; prueba de restauración trimestral.

3.6 Decisión: Wazuh todo en uno

Se elige la arquitectura todo en uno. Con 20 agentes una sola VM cubre la carga, el presupuesto Bajo no admite tres nodos y la empresa no tiene un requisito de alta disponibilidad del SIEM: si el SIEM cae unas horas, los agentes guardan eventos en cola y los reenvían. La arquitectura distribuida se reconsidera si se superan 50 agentes o si un cliente exige disponibilidad contractual del monitoreo.

4. SIEM Wazuh

Wazuh 4.14 quedó instalado todo en uno en `wz-c21pn-01` y monitorea a los agentes `ub-c21pn-01` (Linux, representa el servidor del ERP) y `wc-c21pn-01` (Windows 10), ambos activos en el dashboard. **Los tres escenarios del caso están demostrados con eventos reales:** el cambio en la configuración del ERP (FIM), la fuerza bruta SSH con bloqueo y desbloqueo automáticos, y la vulnerabilidad crítica (analizada como falso positivo en el Anexo D). Además corrieron el SCA (CIS Ubuntu 24.04, 45 %) y la detección de vulnerabilidades. Las tres reglas personalizadas se dispararon. Queda pendiente, como pulido, la captura de `wazuh-logtest` y el tablero guardado.

4.1 Laboratorio montado

El equipo anfitrión es un PC con Windows y 16 GB de RAM que corre VirtualBox. Cada VM tiene dos adaptadores: NAT para descargar paquetes y *host-only* (`192.168.56.0/24`) como red aislada del laboratorio. No hay ninguna conexión a la red de la universidad ni a equipos de terceros.

VM	Rol en el caso	SO	Recursos	IP host-only	Usuario	Estado
`wz-c21pn-01`	Servidor Wazuh (indexer, manager y dashboard)	Ubuntu Server 24.04.5 LTS	4 vCPU · 5 GB RAM · 48 GB	192.168.56.10 (estática)	`socc21pn`	Operativa
`ub-c21pn-01`	Agente Linux; representa el servidor de staging/ERP (SRV-C21PN-STG)	Ubuntu Server 24.04.5 LTS	1 vCPU · 1,5 GB RAM · 20 GB	192.168.56.11 (estática)	`linc21pn`	Operativa
`wc-c21pn-01`	Cliente Windows con agentes de Wazuh y Kaspersky	Windows 10 (ISO oficial)	2 vCPU · 3 GB RAM · 50 GB	192.168.56.12	—	Pendiente

Los nombres siguen la convención `tipo-c21pn-NN` (C21 = caso; PN = Pérez y Niño). El acceso de administración se hace por SSH desde PowerShell con reenvío de puertos de VirtualBox (2222 al servidor y 2223 al agente), no desde la consola de la VM.

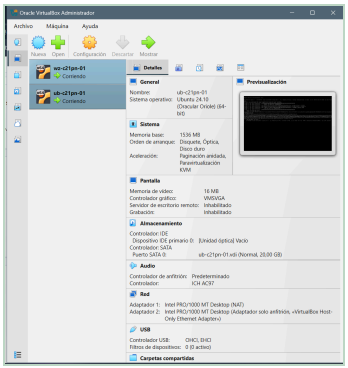


Figura 1. *Las dos VM del laboratorio corriendo en VirtualBox; ub-c21pn-01 con 1536 MB y adaptadores NAT + host-only. (F01_01_laboratorio_virtualbox.png)*

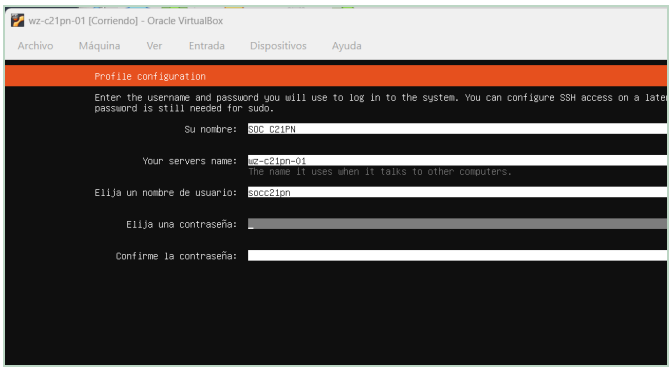


Figura 2. *Instalación de Ubuntu Server en el servidor: hostname wz-c21pn-01 y usuario socc21pn (la contraseña no se muestra).*
(F02_01_instalacion_servidor_wz-c21pn-01.png)

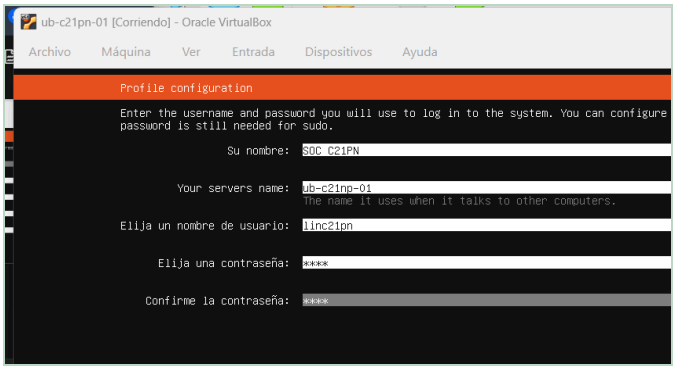


Figura 3. *Instalación del agente Linux. El hostname se escribió por error como ub-c21np-01 y luego se corrigió a ub-c21pn-01 con hostnamectl.*
(F02_02_instalacion_agente_ub-c21pn-01.png)

4.2 Instalación del servidor

Paso	Qué se hizo	Resultado
Red	IP estática 192.168.56.10/24 con netplan en el adaptador host-only	El agente y el navegador del anfitrión llegan al servidor
Disco	El instalador solo usó 23 GB de los 50 asignados; se amplió el volumen LVM con `lvextend`	48 GB disponibles para índices
Paquetes	`apt update` fallaba con el espejo `co.archive.ubuntu.com`; se cambió a `archive.ubuntu.com`	Sistema actualizado
Wazuh	Instalación asistida todo en uno: `sudo bash wazuh-install.sh -a` (rama 4.14)	Indexer, manager y dashboard instalados
Memoria	Se bajó la RAM de la VM de 8 a 5 GB para que cupieran las demás VM; el *heap* del indexer se fijó en 1024 MB en `jvm.options`	El indexer arranca estable (tarda 1–2 min en pasar de *activating* a *active*)
Actualizaciones	Repositorio de Wazuh desactivado después de instalar	Evita que un `apt upgrade` cambie la versión del manager por encima de los agentes

```
# Verificación de los tres servicios (servidor wz-c21pn-01)
sudo systemctl status wazuh-indexer wazuh-manager wazuh-dashboard --no-pager | grep -E "●|Active"
date; whoami; hostname
```

> La captura de `systemctl status` con los tres servicios `active (running)` va en el ZIP de evidencias.

La guía recomienda 8 GB de RAM para el servidor todo en uno. Con 5 GB y el *heap* reducido funciona para un agente y pocas alertas, pero en producción se dimensiona como dice el cap. 3.4 (8 vCPU, 16 GB).

4.3 Agentes

El agente 001 `ub-c21pn-01` (versión 4.14.9, igual a la del manager) se registró contra 192.168.56.10 por los puertos 1515/TCP (registro) y 1514/TCP (eventos). Sus módulos `agentd`, `syscheckd`, `logcollector` y `modulesd` arrancaron a las 03:24:08 UTC del 21/10/2026 (22:24 del 20/10 en Bogotá).

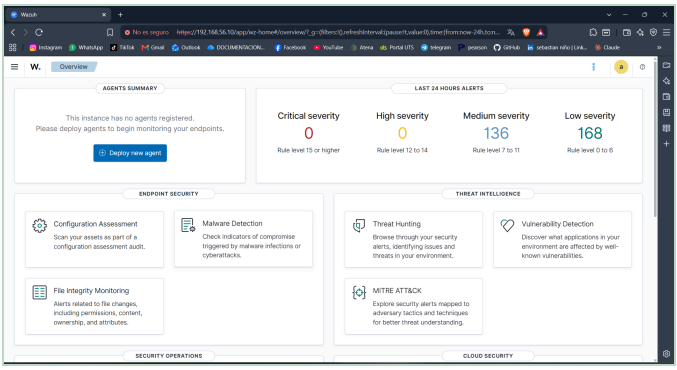


Figura 4. *Dashboard recién instalado: aún sin agentes; las 304 alertas son eventos del propio manager.* *(F02_03_dashboard_sin_agentes.png)*

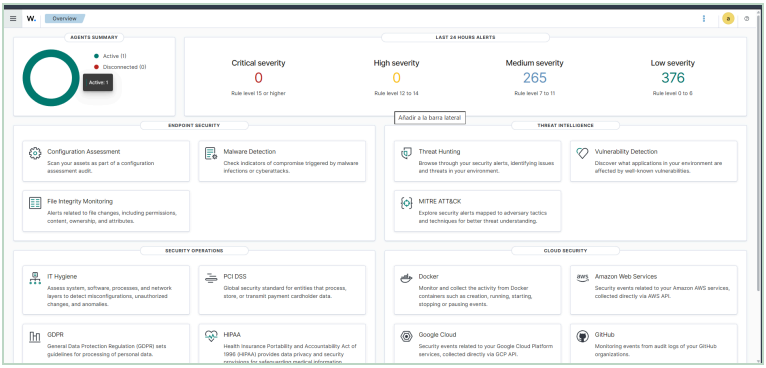


Figura 5. *Dashboard con el agente Linux conectado (Active: 1, Disconnected: 0) y 641 alertas en las últimas 24 h.* *(F02_04_dashboard_agente_activo.png)*

El agente de Windows se instalará en `wc-c21pn-01` con el MSI oficial de la misma versión 4.14.x:

```
# PowerShell como administrador en wc-c21pn-01
msiexec.exe /i wazuh-agent-4.14.9-1.msi /q WAZUH_MANAGER="192.168.56.10" WAZUH_AGENT_NAME="wc-c21pn-01" WAZUH_AGENT_GROUP="windows-estaciones"
NET START WazuhSvc
```

El agente de Windows conectó al manager a las 17:29:42 UTC según su propio log (`Connected to the server`). En el dashboard el resumen quedó con **dos agentes activos y ninguno desconectado**, que son `ub-c21pn-01` (Linux) y `wc-c21pn-01` (Windows 10). Con eso se cumple el requisito de la guía de tener agentes de Windows y Linux reportando.

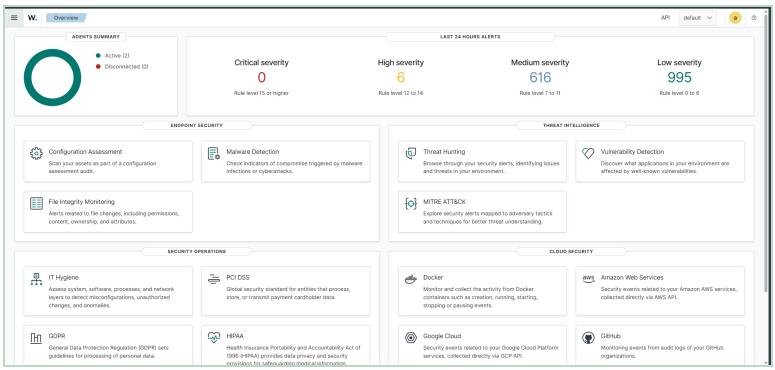


Figura 6. Resumen del dashboard con 2 agentes activos y 0 desconectados; a la derecha, el conteo de alertas de las últimas 24 h (0 críticas, 6 altas). (F02_14_dashboard_dos_agentes_activos.png)

> **Sobre Windows 10.** El caso lista 12 equipos Windows 11, pero la VM cliente se montó con Windows 10 (ISO oficial) por disponibilidad. Se documenta la diferencia: Windows 10 dejó de recibir soporte estándar en octubre de 2025, así que en producción los clientes irían sobre Windows 11; el agente y las reglas funcionan igual en ambos.

Despliegue masivo a los 20 equipos. La empresa no tiene Active Directory, así que no hay GPO. Los 12 Windows reciben el MSI como paquete personalizado desde la consola de Kaspersky (o un script de PowerShell con las mismas variables); los 6 Ubuntu, con un playbook de Ansible desde una estación de desarrollo; los 2 macOS, con el `.pkg` oficial y el archivo `/tmp/wazuh_envs` (verificar compatibilidad con la versión de macOS). Se empieza por los 4 servidores. Los portátiles que salen a clientes reportan por la VPN y, si están desconectados, el agente guarda los eventos en cola. Grupos previstos: `windows-estaciones`, `windows-portatiles`, `macos-gerencia`, `linux-dev`, `linux-dmz`, `linux-internos`.

4.4 Monitoreo de integridad (FIM): escenario 3

Para simular el ERP se creó en el agente el directorio `/etc/odoo` con un `odoo.conf` ficticio. En el `ossec.conf` del agente (bloque `syscheck`) se agregó:

```
<directories check_all="yes" realtime="yes" report_changes="yes">/etc/odoo</directories>
```

`realtime` avisa en segundos sin esperar el escaneo periódico, y `report_changes` guarda qué línea cambió. El FIM empezó a vigilar `/etc/odoo` en tiempo real a las 03:26:29 UTC. La prueba fue agregar una línea al archivo:

```
# Agente ub-c21pn-01
echo "limit_memory_hard = 2684354560" | sudo tee -a /etc/odoo/odoo.conf
echo "prueba" | sudo tee /etc/odoo/nuevo.conf        # archivo nuevo, dispara la regla 554
date; whoami; hostname
```

```
linc21pn@ub-c21pn-01:~$ echo "limit_memory_hard = 2684354560" | sudo tee -a
/etc/odoo/odoo.conf
date; whoami; hostname
limit_memory_hard = 2684354560
mié 21 oct 2026 03:29:04 UTC
linc21pn
ub-c21pn-01
linc21pn@ub-c21pn-01:~$
```

Figura 7. Cambio controlado en /etc/odoo/odoo.conf desde ub-c21pn-01 (03:29:04 UTC). (F02_05_fim_cambio_odoo_conf.png)

En el servidor llegó la alerta 550 *Integrity checksum changed* (nivel 7, MITRE T1565.001) sobre `/etc/odoo/odoo.conf`, con modo `realtime` y atributos cambiados `size, mtime, md5`. La captura muestra la tercera vez que se disparó (03:33:07 UTC).

```
socc21pn@wz-c21pn-01:~$ sudo grep '"syscheck"' /var/ossec/logs/alerts/alerts
.json | grep "/etc/odoo" | tail -n 1 | cut -c1-700
{"timestamp":"2026-10-21T03:33:07.908+0000","rule":{"level":7,"description":
"Integrity checksum changed.","id":"550","mitre":{"id":["T1565.001"],"tactic
":["Impact"],"technique":["Stored Data Manipulation"]},"firedtimes":3,"mail"
:false,"groups":["ossec","syscheck","syscheck_entry_modified","syscheck_file
"],"pci_dss":["11.5"],"gpg13":["4.11"],"gdpr":["II_5.1.f"],"hipaa":["164.312
.c.1","164.312.c.2"],"nist_800_53":["SI.7"],"tsc":["PI1.4","PI1.5","CC6.1","
CC6.8","CC7.2","CC7.3"]},"agent":{"id":"001","name":"ub-c21pn-01","ip":"192.
168.56.11"},"manager":{"name":"wz-c21pn-01"},"id":"1792553587.2413327","full
_log":"File '/etc/odoo/odoo.conf' modified\nMode: realtime\nChanged attribut
es: size,mtime,m
socc21pn@wz-c21pn-01:~$
```

Figura 8. *Alerta 550 en alerts.json del manager: archivo /etc/odoo/odoo.conf modificado en el agente 001 ub-c21pn-01. (F02_06_fim_alerta_550_json.png)*

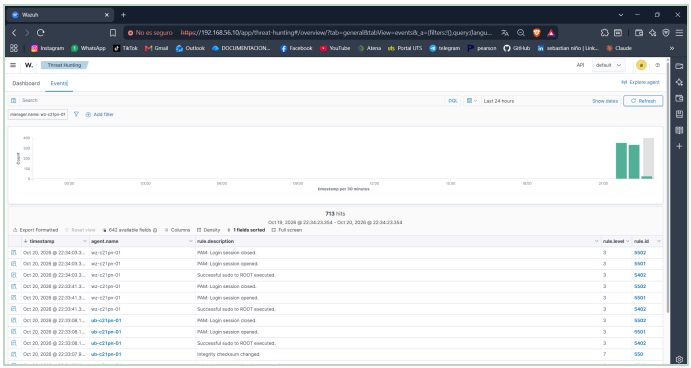


Figura 9. *Threat Hunting en el dashboard: la alerta 550 de ub-c21pn-01 (22:33:07 hora de Bogotá) junto a eventos de sesión y sudo. (F02_07_threat_hunting_eventos.png)*

4.5 Evaluación de configuración (SCA)

El SCA corrió sobre `ub-c21pn-01` con la política **CIS Ubuntu Linux 24.04 LTS Benchmark v1.0.0**. El escaneo del 21/10/2026 a las 12:39:03 (hora de Bogotá) dio **109 controles aprobados, 128 fallidos y 42 no aplicables, con un puntaje de 45 %** sobre 279 controles.

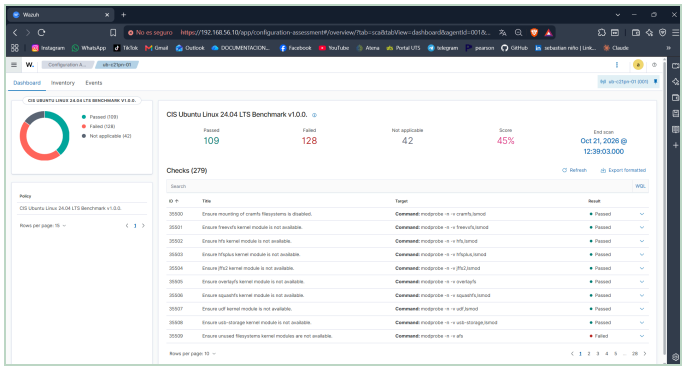


Figura 10. *SCA de ub-c21pn-01: CIS Ubuntu 24.04 v1.0.0, 109 aprobados, 128 fallidos, puntaje 45 %. (F02_15_sca_cis_ubuntu.png)*

Un 45 % es lo normal en una instalación por defecto: el benchmark del CIS es muy exigente. Se eligen tres controles fallidos para remediar primero, por su relación con los riesgos del caso:

Control CIS fallido	Qué cambiar	Impacto	Responsable
35509 — Módulos de sistemas de archivos no usados no disponibles	Deshabilitar módulos como `afs` en `/etc/modprobe.d`	Reduce superficie de ataque del kernel	Admin. de TI
Endurecimiento de SSH (Banner, MaxAuthTries, LoginGraceTime)	Ajustar `/etc/ssh/sshd_config`	Menos ventana para la fuerza bruta (R-03)	Admin. de TI

Control CIS fallido	Qué cambiar	Impacto	Responsable
Política de contraseñas y bloqueo de cuentas	`pam_pwquality` y `faillock`	Dificulta el abuso de credenciales	Admin. de TI

El mismo ejercicio se repite con el agente Windows (política CIS Windows) y queda como tarea de endurecimiento continuo.

4.6 Detección de vulnerabilidades: escenario 1

El módulo cruza el inventario de paquetes del agente con la base de CVE de Wazuh. En el manager queda así (verificar sintaxis de la 4.14):

```
<vulnerability-detection>
  <enabled>yes</enabled>
  <index-status>yes</index-status>
  <feed-update-interval>60m</feed-update-interval>
</vulnerability-detection>
```

Tras sincronizar la base, el dashboard reportó para `ub-c21pn-01`: **242 vulnerabilidades críticas, 1.370 altas, 553 medias y 49 bajas, más 1.597 en evaluación**. El dato llamativo es que las 242 críticas (y en realidad los 3.811 hallazgos del inventario) apuntan a un solo paquete: `linux-image-6.8.0-147-generic`, versión `6.8.0-147.147`.

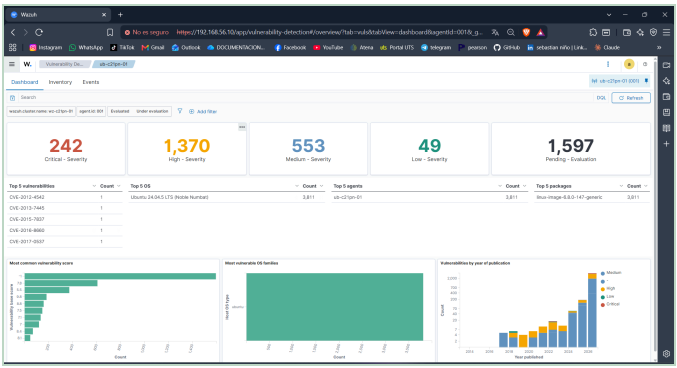


Figura 11. *Vulnerability Detection de ub-c21pn-01: 242 críticas, 1.370 altas; el único paquete afectado es el kernel linux-image-6.8.0-147-generic. (F02_16_vulnerabilidades_dashboard.png)*

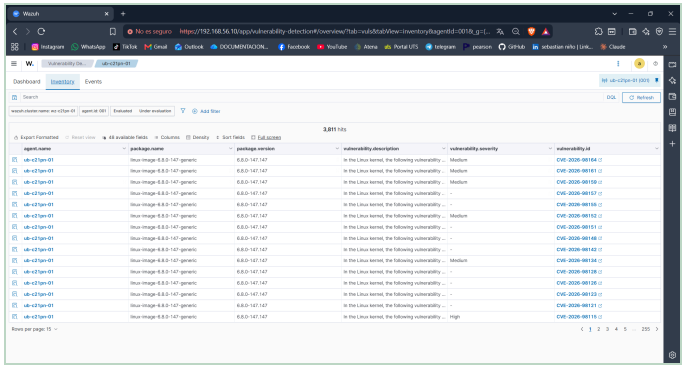


Figura 12. *Inventario de vulnerabilidades: 3.811 hallazgos, todos sobre linux-image-6.8.0-147-generic 6.8.0-147.147. (F02_21_vuln_inventario_kernel.png)*

Que todas las críticas caigan sobre el kernel recién instalado es sospechoso, así que se hizo triage sobre un CVE crítico antes de proponer un parcheo masivo. El caso completo está en el **Anexo D**; el resumen:

- **CVE analizado:** CVE-2026-72422 (CVSS 9.8, use-after-free en ksmbd, el servidor SMB del kernel).
- **Versión instalada vs. corregida:** Ubuntu declara el CVE corregido en `6.8.0-147.147` para noble 24.04, que es justo la versión instalada; la base de Canonical en Wazuh indica afectadas solo las versiones *anteriores* a `6.8.0-`

`147`, y `dpkg --compare-versions 6.8.0-147.147 lt 6.8.0-147` devuelve falso.

- **Superficie de ataque:** `lsmod` no muestra `ksmbd` cargado y `ss` no muestra nada escuchando en 445 ni 139, así que la pieza vulnerable ni siquiera está activa.
- **Clasificación:** falso positivo (provisional). Se verificaron también CVE-2026-64268 y CVE-2026-72399, los dos corregidos en la misma versión; los otros 239 comparten paquete y versión y se evalúan por muestreo.

Conclusión para el caso: el escenario 1 se demuestra no con un parcheo apurado, sino mostrando el triage correcto de una alerta crítica. Un CVSS alto describe la gravedad en abstracto; el riesgo real depende de si el componente está presente y expuesto. Las evidencias (fichas de Ubuntu y de la CTI de Wazuh) van en el Anexo D.

4.7 Reglas personalizadas

Las tres reglas viven en `/var/ossec/etc/rules/local_rules.xml` del manager y están atadas a los escenarios del caso:

```
<group name="local,c21pn,erp,">
  <rule id="100210" level="10">
    <if_sid>550</if_sid>
    <match>/etc/odoo/</match>
    <description>C21: Modificacion de configuracion del ERP en /etc/odoo.</description>
    <mitre><id>T1565.001</id></mitre>
  </rule>

  <rule id="100211" level="10">
    <if_sid>554</if_sid>
    <match>/etc/odoo/</match>
    <description>C21: Archivo nuevo creado en la configuracion del ERP.</description>
  </rule>

  <rule id="100212" level="12">
    <if_sid>5712</if_sid>
    <description>C21: Fuerza bruta SSH contra servidor del ERP (severidad alta).</description>
    <mitre><id>T1110</id></mitre>
  </rule>
</group>
```

Regla	Hereda de	Nivel	Por qué ese nivel	Disparos en la prueba
100210	550 (checksum modificado)	10	La 550 queda en 7, igual que cualquier archivo de `/etc`; un cambio en la configuración del ERP merece revisión inmediata del N1	1
100211	554 (archivo nuevo)	10	Un archivo nuevo en la configuración del ERP puede ser una puerta trasera o un módulo no autorizado	1
100212	5712 (fuerza bruta SSH)	12	Sube a severidad Alta porque el objetivo es el servidor del ERP con datos de clientes; además dispara el bloqueo automático	4

Conteo hecho en el manager con:

```
for r in 100210 100211 100212; do echo "$r: $(sudo grep -c "\"id\":\"$r\""
/var/ossec/logs/alerts/alerts.json)"; done
```

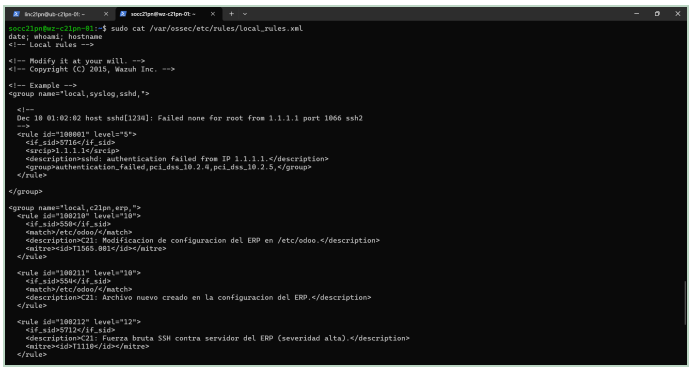


Figura 13. *local_rules.xml en wz-c21pn-01 con las reglas 100210, 100211 y 100212.* *(F02_08_local_rules_parte1.png)*

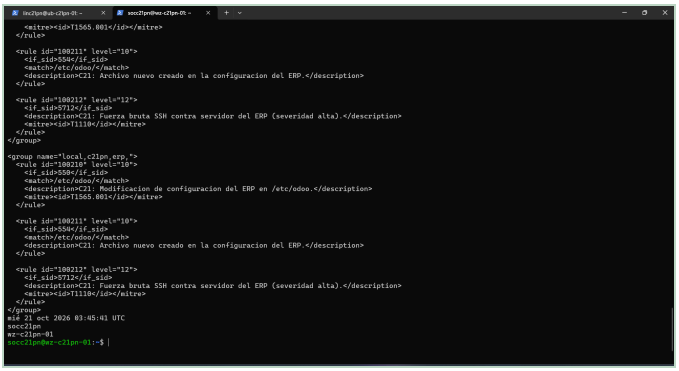


Figura 14. *Final del archivo con fecha (03:45:41 UTC), usuario socc21pn y hostname wz-c21pn-01. El bloque del grupo c21pn aparece dos veces.* *(F02_09_local_rules_parte2.png)*

Lo que aprendimos. La primera versión de 100210 y 100211 filtraba con `<field name="syscheck.path">` y nunca coincidía; funcionó al cambiarla por `<match>` sobre la ruta del log. Antes de reiniciar el manager se valida la sintaxis con `sudo /var/ossec/bin/wazuh-analysisd -t`. La figura anterior muestra que el bloque quedó **pegado dos veces** en el archivo: hay que borrar el duplicado, porque IDs repetidos generan advertencias en `analysisd`. El repositorio ya tiene la versión limpia.

La guía pide la prueba con `wazuh-logtest`. Para 100212 basta pegar líneas de fallo de SSH; para 100210 y 100211 se usa la línea de log del FIM:

```
sudo /var/ossec/bin/wazuh-logtest
# pegar 8 o más veces:
# Oct 21 03:47:09 ub-c21pn-01 sshd[15748]: Invalid user usuarioinexistente from 192.168.56.1 port
59189
```

> La salida de `wazuh-logtest` (fase 3, id 100212) se agrega al ZIP de evidencias.

4.8 Respuesta activa: escenario 2

En el `ossec.conf` del manager se asoció el comando `firewall-drop` a la regla 100212, con bloqueo de 180 segundos (corto a propósito para el laboratorio). En el agente se instaló `iptables`, que es lo que usa el script.

```
<active-response>
  <command>firewall-drop</command>
  <location>local</location>
  <rules_id>100212</rules_id>
  <timeout>180</timeout>
</active-response>
```

La fuerza bruta se generó desde el equipo anfitrión (192.168.56.1, dentro de la red host-only) contra `ub-c21pn-01`, con un usuario que no existe. No se usaron las VM como origen para no cortar la comunicación agente–servidor.

```
# 10 intentos con un usuario inexistente contra el agente (solo red host-only)
for i in $(seq 1 10); do ssh -o BatchMode=yes -o ConnectTimeout=3 -o StrictHostKeyChecking=no \
  usuarioinexistente@192.168.56.11 exit 2>/dev/null; done; date; whoami; hostname
# Equivalente en PowerShell del anfitrión:
# 1..10 | % { ssh -o BatchMode=yes -o ConnectTimeout=3 usuarioinexistente@192.168.56.11 exit }
```

Cronología real (UTC; restar 5 h para Bogotá):

Hora UTC	Evento	Fuente
03:35:14	Primeros fallos: reglas 5710 (nivel 5) y 5712 (nivel 10, 8 intentos)	Wazuh
03:40:28	La regla 100212 se dispara por primera vez	Wazuh
03:47:08–09	Nueva ráfaga: `Invalid user usuarioinexistente from 192.168.56.1`, puertos 59184–59190	sshd (journald)
03:47:10	Alerta 100212 nivel 12 y `firewall-drop` agrega `DROP 192.168.56.1` en INPUT	active-responses.log
03:47:10	Línea `Aborted`: la regla se disparó otra vez con la IP ya bloqueada (comportamiento esperado)	active-responses.log
03:47:38 y 03:48:29	`iptables -L INPUT` sigue mostrando el DROP	Agente
03:50:12	`firewall-drop` ejecuta `delete` y quita el DROP (ciclo `Starting → delete → Ended`)	active-responses.log

El bloqueo duró de 03:47:10 a 03:50:12, es decir **182 segundos**, coherente con el timeout de 180 s. El log muestra además un segundo ciclo completo a las 17:40:15 (otra repetición de la prueba), lo que confirma que el mecanismo es repetible.

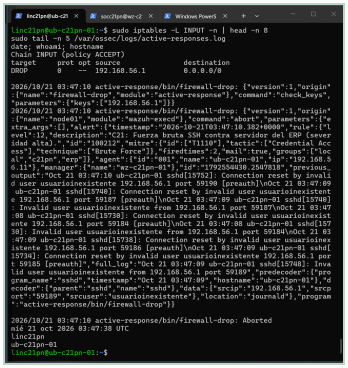


Figura 15. *iptables con DROP para 192.168.56.1 y active-responses.log con la alerta 100212 (T1110, srcuser usuarioinexistente). (F02_10_active_response_drop_y_log.png)*

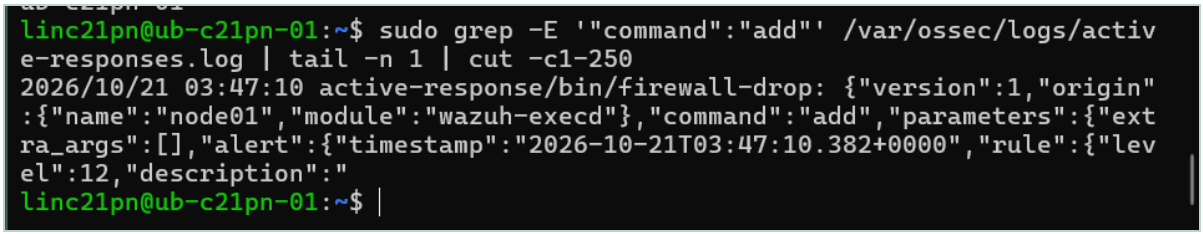


Figura 16. *Comando "add" de firewall-drop a las 03:47:10 UTC. (F02_11_active_response_comando_add.png)*

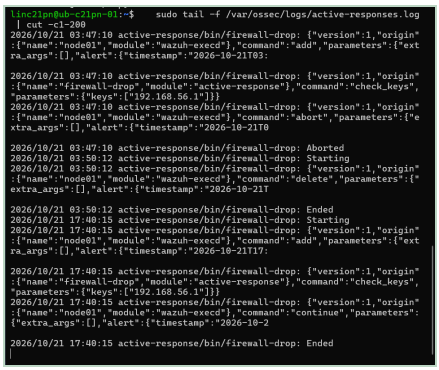


Figura 17. *Desbloqueo automático: a las 03:50:12 UTC el comando "delete" retira el DROP (ciclo Starting → delete → Ended); abajo, un segundo ciclo a las 17:40:15.* *(F02_18_active_response_desbloqueo.png)*

En la prueba se bloqueó justamente al equipo del administrador, que es el error que la guía advierte. En producción la respuesta activa lleva lista blanca para la red del SOC y la estación de TI:

```
<global>
  <white_list>192.168.56.10</white_list>   <!-- en producción: VLAN 90 del SOC y PC de TI -->
</global>
```

4.9 Tablero y notificaciones

Se creará el tablero **C21-PN – SOC N1 – Resumen** con alertas por severidad (`rule.level`), las reglas 100210/100211/100212, eventos FIM por ruta, fallos de autenticación, estado de los agentes y vulnerabilidades por severidad. Se guardan tres búsquedas, una por escenario: `rule.id:(100210 or 100211)` , `rule.id:(5710 or 5712 or 100212)` y `data.vulnerability.severity:Critical` .

> La captura del tablero guardado va en el ZIP de evidencias.

Para el correo de nivel ≥ 10 Wazuh necesita un relé SMTP local (Postfix) porque no autentica contra servidores externos. En el laboratorio se documenta la configuración y se puede usar el plugin de alertas del dashboard como alternativa.

4.10 Endurecimiento y hora

Como parte del endurecimiento se cambió la contraseña del usuario del agente (`passwd` en `ub-c21pn-01`); nunca se escriben contraseñas en el informe ni en las capturas.

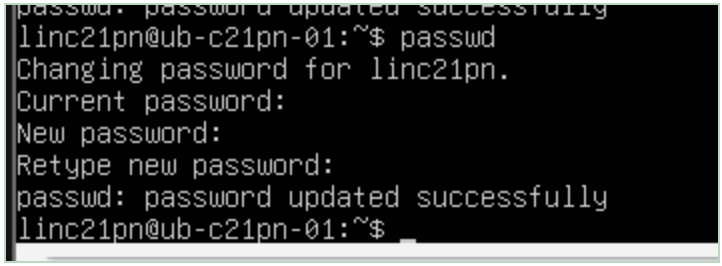


Figura 18. *Cambio de contraseña del usuario linc21pn en el agente (passwd: password updated successfully). La contraseña no aparece.* *(F02_20_hardening_password.png)*

Sobre la hora: las VM quedaron en UTC, por eso las capturas de terminal dicen 03:xx o 17:xx y el dashboard, que usa la hora del navegador, muestra la hora de Colombia (22:xx o 12:xx). Los logs de Windows usan la hora local de Colombia (UTC−5). En cada captura y ticket se anota la zona. La guía pide una sola zona: se homologa con `sudo timedatectl set-timezone America/Bogota` en las dos VM. Otras tareas de endurecimiento: credenciales por defecto del indexer, usuario de solo lectura para el N1, respaldo de `/var/ossec/etc` e instantáneas de las VM (ya se toman al apagar).

> **Nota sobre los certificados.** El dashboard se abre como «No es seguro» porque usa el certificado autofirmado que genera el instalador en el laboratorio. En producción se reemplaza por un certificado válido antes de exponerlo.

4.11 Estado de las pruebas

Prueba de la guía	Estado	Evidencia
Instalación y servicios	Hecha	3 servicios `active (running)`
Agente Linux activo	Hecha	Agente 001, 4.14.9
Agente Windows activo	Hecha	2 agentes Active en el dashboard; log `Connected to the server` 17:29:42 UTC
FIM: archivo modificado y nuevo	Hecha	Reglas 550/100210 y 554/100211
Fuerza bruta SSH + active response	Hecha	Reglas 5712/100212, DROP 03:47:10 UTC
Desbloqueo automático	Hecha	`delete` a las 03:50:12 UTC (182 s)
SCA	Hecha	CIS Ubuntu 24.04, puntaje 45 % (109/128/42)
Vulnerabilidades (escenario 1)	Hecha	242 críticas; CVE-2026-72422 analizado como falso positivo (Anexo D)
Reglas personalizadas (≥ 3)	Hechas y disparadas	3 reglas; falta la captura de `wazuh-logtest`
Fallos de login en Windows	Opcional	Agente Windows ya activo; prueba puntual pendiente
Tablero	Por capturar	Diseño definido (4.9)
Tablero y notificaciones	Pendiente	—

5. EDR/XDR Kaspersky

Se elige **Kaspersky Next EDR Foundations** con Kaspersky Security Center (KSC) local en la VLAN 90: es el nivel que cabe en un presupuesto Bajo, cubre Windows, macOS y Linux, y la consola local permite exportar eventos a Wazuh dentro de la red aislada. La instalación, la prueba EICAR y la integración se ejecutan en la siguiente etapa del laboratorio; las capturas esperadas están marcadas en 5.10.

5.1 Selección de la edición

Kaspersky Next viene en tres ediciones: EDR Foundations, EDR Optimum y XDR Expert (ayuda oficial de Kaspersky Next); las tres incluyen perfiles de seguridad para Windows, macOS y Linux.

Criterio	Next EDR Foundations	Next EDR Optimum	Next XDR Expert
Capacidad EDR	Básica: análisis de causa raíz	Esencial: respuesta guiada, IoC, más automatización	XDR con más fuentes y caza de amenazas
Consola	Nube o local	Nube o local	Local / híbrida
SO cubiertos en el caso	Windows, macOS, Linux	Windows, macOS, Linux (EDR completo más fuerte en Windows)	Windows, macOS, Linux
Ajuste al caso C21	Suficiente para N1: detección, cuarentena, aislamiento, control de USB y web	Mejor investigación; útil si el N2 externo la usa	Sobredimensionado para 20 equipos y presupuesto Bajo
Costo relativo	Menor	Medio	Alto
Decisión	**Elegida**	Alternativa si la cotización cabe en el OPEX	Descartada

Los precios por equipo y la vigencia salen de la cotización de un distribuidor autorizado en Colombia. **[PENDIENTE COTIZACIÓN]** Para el laboratorio se usa la prueba oficial de 30 días; su fecha de vencimiento se registra aquí: [fecha de activación] → [fecha de vencimiento]. Hay que activarla cerca del Punto de control 1 para que siga viva en la sustentación.

Riesgo de proveedor. Estados Unidos prohibió desde 2024 la venta de productos Kaspersky en su territorio. En Colombia no hay una restricción equivalente conocida, pero un cliente con casa matriz estadounidense o contratos con el Estado podría vetar al fabricante. Se registra como riesgo de cadena de suministro y la arquitectura no depende de Kaspersky para la correlación: Wazuh sigue siendo el centro.

5.2 Dónde va la consola

La consola en la nube (KSC Cloud Console) puede exportar eventos a un SIEM en formato Syslog (Kaspersky), pero desde la nube no alcanza un Wazuh dentro de una red host-only. Por eso:

- **Laboratorio (opción A, preferida):** KSC local en una VM Windows Server de evaluación, `ks-c21pn-01` (192.168.56.13, 4 GB de RAM). Como el anfitrión tiene 16 GB, durante las pruebas de Kaspersky se apaga `ub-c21pn-01` para que quepan Wazuh (5 GB), Windows (3 GB) y KSC.
- **Laboratorio (opción B, si no alcanza la RAM):** consola KSC en la nube en prueba de 30 días. Como la nube no llega a la red host-only, los eventos llegan a Wazuh por el agente de Wazuh en `wc-c21pn-01`, leyendo el canal de eventos de Kaspersky de Windows (`<localfile>` con `eventchannel`). Se documenta como desviación de la integración Syslog/CEF.
- **Producción:** KSC local en una VM de la VLAN 90 junto a Wazuh. Se evalúa instalar el Servidor de Administración sobre Linux para no comprar licencia de Windows Server (verificar soporte en la versión vigente).

5.3 Grupos de administración

Grupo	Equipos	Política
Estaciones	PC-C21PN-01 a 08	Estaciones
Portátiles remotos	LT-C21PN-01 a 04, MAC-C21PN-01 y 02	Portátiles (actualización por Internet si no ven el KSC, cifrado de disco recomendado)
Desarrollo	DEV-C21PN-01 y 02	Estaciones + reglas de firewall para herramientas de desarrollo
Servidores DMZ	SRV-C21PN-DEMO y STG	Servidores, análisis fuera de horario, USB bloqueado
Servidores internos	SRV-C21PN-DB y BKP	Servidores con exclusiones mínimas de base de datos
Laboratorio	VM de prueba	Pruebas, separada de producción

5.4 Políticas

Política	Configuración en C21	Por qué en este caso
Protección en tiempo real	Archivos, correo y web; desinfectar y si no, cuarentena	Línea base contra malware conocido
Control de dispositivos	Almacenamiento USB bloqueado en todos; excepción temporal solo por ticket aprobado	Los consultores mueven bases de clientes: el USB es la vía más fácil de fuga (R-11)
Control web	Bloquear malware, phishing, anonimizadores y almacenamiento en la nube no corporativo	Reduce robo de credenciales de VPN (R-06) y salida de bases por servicios personales
Firewall del endpoint	Activo, perfil "red pública" en portátiles fuera de la oficina	Los consultores se conectan en redes de clientes y Wi-Fi público
Prevención de exploits y comportamiento	Activas, con reversión de acciones de ransomware	R-04
Protección de la configuración	Contraseña para desinstalar o pausar	Que nadie apague el agente por "lentitud"

Política	Configuración en C21	Por qué en este caso
Actualizaciones	Desde el KSC cada hora; portátiles fuera de red, desde servidores de Kaspersky	Firmas al día aunque no haya VPN

5.5 Tareas programadas

Tarea	Frecuencia	Ventana
Actualización de bases	Cada hora	Continua, con reintento
Análisis de áreas críticas	Diario	12:30 (almuerzo) en estaciones; 23:00 en servidores
Análisis completo	Semanal	Viernes 20:00, escalonado por grupo
Inventario de software y vulnerabilidades	Semanal	Lunes 6:00

En SRV-C21PN-BKP el análisis completo no coincide con la ventana de respaldo (2:30–3:00).

5.6 Exclusiones

Exclusión	Equipo	Motivo	Aprobó	Revisar
`/var/lib/postgresql/*/main`	SRV-C21PN-DB	Bloqueos de archivos y rendimiento de PostgreSQL	Responsable del SOC	3 meses
`/var/ossec/queue`	Servidores Linux	Evitar bloqueos de lectura del agente de Wazuh	Responsable del SOC	3 meses

No se excluyen `/opt/odoo/custom-addons`, ni carpetas de usuario, ni `Descargas`: los módulos de Odoo son Python interpretado y no hay compilación pesada que lo justifique. Cada exclusión nace de un ticket de cambio en GLPI.

5.7 Acciones de respuesta

Acción	Analista N1	N2 / responsable
Poner un archivo en cuarentena	Sí (PB-02)	Sí
Aislar un equipo de la red	Solo en severidad Alta o Crítica, y notifica a N2	Sí; decide cuándo levantarlo
Terminar un proceso malicioso	Sí, si el playbook lo autoriza	Sí
Restaurar o reinstalar	No	Sí, con aprobación del responsable
Modificar políticas y exclusiones	No (propone por ticket)	Sí, con registro de cambio

5.8 Integración con Wazuh

1. En KSC: integración con SIEM → servidor 192.168.56.10 en el laboratorio (VLAN 90 en producción), puerto 514, UDP (TCP o TLS en producción), formato CEF para eventos generales. Si se necesitan eventos propios de las aplicaciones, KSC exige formato Syslog en lugar de CEF y el decoder cambia.
2. En Wazuh: bloque `<remote>` de syslog en 514/UDP con `allowed-ips` = 192.168.56.13.
3. Captura de una línea real en `archives.log` (con `logall` activo solo durante la prueba), ajuste del decoder `kaspersky-cef` de la guía y reglas 100200/100201 validadas con `wazuh-logtest`.

5.9 Plan de despliegue y pruebas

Paquete con Network Agent + Kaspersky Endpoint Security; tarea remota para Windows en la oficina, paquete autónomo para portátiles y Mac, paquetes .deb para Ubuntu. Primero servidores, luego estaciones y por último portátiles cuando vuelvan a la oficina.

Prueba	Resultado esperado	Evidencia
EICAR en wc-c21pn-01 (solo VM propia, sin carpetas compartidas)	Detección y cuarentena en la consola	

Prueba	Resultado esperado	Evidencia
USB virtual conectado a la VM	Bloqueo registrado	
EICAR visto en Wazuh	Alerta 100200/100201	
Desinstalar sin contraseña	Operación rechazada	

> Las capturas de esta fase (consola, política, EICAR y su llegada a Wazuh) se agregan al ejecutarla; van en el ZIP de evidencias, no en el cuerpo del informe.

6. GLPI en la nube

GLPI se despliega en un VPS pequeño con HTTPS y queda configurado como la mesa de servicio del SOC: tres subentidades, cinco perfiles, 10 usuarios ficticios, categorías de seguridad atadas a los escenarios del caso y SLA iguales a los del manual (cap. 8). La instancia, el certificado y las capturas son trabajo de laboratorio. ****

6.1 Ficha de diseño en la nube

Decisión	Valor	Justificación
Modelo	GLPI autoadministrado en una VM	Control total de la configuración y costo mínimo
Proveedor y región	[elegir: proveedor con región en Bogotá, São Paulo o EE. UU. Este]	Latencia baja desde Bucaramanga, instantáneas incluidas, grupos de seguridad
Tamaño	2 vCPU, 4 GB RAM, 40 GB SSD, Ubuntu Server 24.04	10 usuarios y \~26 activos; holgura para adjuntos
Versión	GLPI estable vigente (10.0.x o 11.0.x; verificar requisitos de PHP y MariaDB)	DocumentRoot en `/var/www/glpi/public`
Red	IP fija; grupo de seguridad: 443 abierto, 80 solo para validar el certificado, 22 solo desde la IP de administración	Superficie mínima
Dominio	`soporte.erppymefacil.example` como marcador en el informe; en el laboratorio, un subdominio propio o gratuito de pruebas	HTTPS válido con Let's Encrypt
Respaldos	Volcado diario de la base y de `files/` y `config/`, 14 días, copia fuera del VPS + instantánea semanal	Prueba de restauración documentada
Costo mensual	[valor de la calculadora oficial del proveedor, con fecha]	Va al presupuesto (cap. 9)

6.2 Entidades, ubicaciones y calendarios

- **Entidad raíz:** ERP Pyme Fácil S.A.S. → subentidades **Gerencia**, **Consultoría** y **Desarrollo y TI**.
- **Ubicaciones:** Oficina Bucaramanga › Puestos; Oficina Bucaramanga › Rack de servidores; En cliente (portátiles fuera de sede); Nube (VPS GLPI).
- **Calendarios:** "Laboral C21" de lunes a viernes 7:00–19:00 con festivos de Colombia 2026; "24×7" para severidad crítica y alta.

6.3 Perfiles y usuarios

Perfil	Base	Quién	Permisos clave
Super administrador	Super-Admin	Cuenta nominal `adm-lmartinez`, solo para configuración	Todo; sin uso diario
Administrador SOC	Copia de Admin	Responsable del SOC	Tickets, activos, categorías, SLA y reglas; sin configuración global

Perfil	Base	Quién	Permisos clave
Analista N1	Copia de Technician	Analista N1 y su respaldo	Crear, actualizar y resolver tickets; ver activos; base de conocimiento; no borra tickets
Supervisor	Observer	Gerencia general	Ver tickets y reportes; validar soluciones
Autoservicio	Self-Service	Resto del personal	Crear y ver sus tickets; KB pública

Los 10 usuarios ficticios (uno por empleado). Correos en el dominio reservado `erppymefacil.example`.

Usuario	Nombre (ficticio)	Cargo	Entidad	Perfil	Grupo
agomez	Andrés Gómez Peña	Gerente general	Gerencia	Supervisor	Usuarios
lmartinez	Laura Martínez Ríos	Gerente de operaciones y responsable del SOC	Gerencia	Administrador SOC	SOC N2 (interno)
cruiz	Camilo Ruiz Duarte	Líder de consultoría	Consultoría	Autoservicio	Usuarios
dhernandez	Daniela Hernández Mora	Consultora contable	Consultoría	Autoservicio	Usuarios
jcastro	Jorge Castro Vega	Consultor de nómina	Consultoría	Autoservicio	Usuarios
vortiz	Valeria Ortiz Salazar	Consultora de inventarios	Consultoría	Autoservicio	Usuarios
sjimenez	Santiago Jiménez Prada	Consultor de facturación electrónica	Consultoría	Autoservicio	Usuarios
mrojas	Mateo Rojas Cárdenas	Desarrollador Odoo	Desarrollo y TI	Autoservicio	Usuarios
pvargas	Paula Vargas León	Administradora de TI y N1 de respaldo	Desarrollo y TI	Analista N1	SOC N1
ftorres	Felipe Torres Quintero	Analista de soporte y SOC N1	Desarrollo y TI	Analista N1	SOC N1

Aparte de los 10 empleados se crea una cuenta técnica `n2-proveedor` (perfil Analista N1, grupo SOC N2) para el soporte N2 externo, desactivada salvo cuando hay un caso escalado.

6.4 Categorías ITIL

Categoría raíz	Subcategorías
Seguridad	Malware / EDR · Acceso no autorizado y autenticación · Phishing e ingeniería social · Integridad de archivos (FIM) · Configuración del ERP (odoo.conf) · Dispositivos extraíbles (USB) · Reconocimiento de red · Cuentas y privilegios · Vulnerabilidades · Fuga de datos / datos reales en pruebas
Incidente de TI	Hardware · Software · Red · Servidor de demostración caído
Solicitud	Alta y baja de usuarios · Instalación de software · Acceso a recursos · Nueva demo para cliente
Cambio	Configuración de seguridad · Exclusiones del EDR · Reglas del SIEM · Cambios en odoo.conf y módulos · Parches de servidores

"Nueva demo para cliente" existe a propósito: toda demo nace con un ticket que exige marcar que los datos están enmascarados. Así el riesgo R-01 queda con un control en el flujo y no solo en una política escrita.

6.5 Prioridad, SLA y OLA

Severidad SOC	Prioridad GLPI	Reconocer (TTO)	Resolver o contener (TTR)	Calendario
Crítica	Mayor	15 min	4 h	24×7
Alta	Muy alta	30 min	8 h	24×7 con guardia
Media	Media	2 h	24 h	Laboral C21

Severidad SOC	Prioridad GLPI	Reconocer (TTO)	Resolver o contener (TTR)	Calendario
Baja	Baja	8 h hábiles	72 h	Laboral C21
Informativa	Muy baja	1 día hábil	5 días hábiles	Laboral C21

OLA N1 → N2: el N2 reconoce un caso escalado en 30 min si es crítico, 2 h si es alto y el siguiente día hábil si es medio. Nivel de escalamiento en GLPI: al 75 % del TTO sin tomar en cuenta, notifica a `lmartinez`; al 100 %, sube la prioridad un nivel.

6.6 Plantilla "Alerta de seguridad" y reglas de negocio

La plantilla obliga: título con formato `[Origen] [ID] — resumen`, categoría de Seguridad, origen (Wazuh, Kaspersky, NGFW, Usuario), elemento asociado del inventario, urgencia e impacto y la descripción guiada del Anexo C (ID de regla, fecha y hora en America/Bogota, activo y usuario, IP, qué pasó, evidencias, acciones del N1 y decisión).

Regla de negocio	Condición	Acción
Asignar al SOC	Categoría = Seguridad > *	Grupo asignado = SOC N1
Fuga de datos	Subcategoría = Fuga de datos / datos reales en pruebas	Impacto = Muy alto; notificar a responsable del SOC
Servidor expuesto	Elemento = SRV-C21PN-DEMO o SRV-C21PN-STG	Urgencia +1
SLA por prioridad	Prioridad = Mayor / Muy alta / Media / Baja / Muy baja	Asignar el SLA de TTO y TTR correspondiente
Phishing por correo	Ticket creado por el receptor `reportes@erppymefacil.example`	Categoría = Phishing; grupo = SOC N1

6.7 Notificaciones

SMTP de la cuenta creada para el ejercicio, puerto 587 con STARTTLS y contraseña de aplicación (nunca la cuenta personal). Plantillas activas: ticket nuevo, asignado, escalado por SLA, seguimiento y solucionado. Evidencia: captura del correo recibido.

6.8 Inventario de activos

- GLPI Agent en las VM del laboratorio apuntando a `/front/inventory.php`; en producción se distribuye junto con el agente de Wazuh (mismos métodos del cap. 4.8).
- Registro manual: NGFW, switch, 2 AP, VPS de GLPI, dominio, licencia de Kaspersky (con fecha de vencimiento), contrato del ISP y contrato del N2 externo.
- Estados del ciclo de vida: En uso · En laboratorio · En cliente · En reparación · Retirado.
- Cada ticket de seguridad se vincula al activo afectado; así el historial de SRV-C21PN-DEMO muestra todas sus vulnerabilidades y cambios.

6.9 Base de conocimiento (14 artículos)

N.°	Artículo	Visible para
1–9	Playbooks PB-01 a PB-09 (cap. 8.6)	Analista N1, N2
10	Matriz de severidad y SLA	Analista N1, N2, Supervisor
11	Procedimiento de escalamiento a N2 y plantilla	Analista N1, N2
12	Cómo reportar un correo sospechoso	Todos
13	Política de uso de dispositivos USB	Todos
14	Política de datos enmascarados para demos y staging	Todos

6.10 Reportes y diseño corporativo

- Tablero con tickets por estado, categoría y prioridad, SLA incumplidos y tickets sin asignar.
- Exportación mensual a CSV para calcular MTTA, MTTR, tasa de falsos positivos y cumplimiento de SLA (cap. 8.9).
- Logo ficticio propio (sin marcas reales), colores corporativos azul petróleo y gris, mensaje de bienvenida con la política de uso aceptable y el canal `soc-n1@erppymefacil.example`.

La lista de verificación de la puesta en marcha (guía, sección 4.16) se marca en el laboratorio.

> Las capturas de GLPI (HTTPS, entidades y perfiles, SLA/OLA, inventario, respaldo y restauración) se agregan al desplegar la instancia; van en el ZIP de evidencias.

7. Firewall de nueva generación (NGFW)

El caso necesita un NGFW de escritorio con al menos 400 Mbps de rendimiento con seguridad activa, VPN para 10 usuarios y una DMZ para dos servidores. Se preseleccionan Fortinet FortiGate 50G, Palo Alto PA-410 y Ruijie RG-WALL 1600-Z3200-S; ningún precio aparece hasta tener las tres cotizaciones reales. **[PENDIENTE COTIZACIONES]**

7.1 Requisitos del caso

Requisito	Valor	De dónde sale
Enlace a Internet	300 Mbps fibra, un solo proveedor	Supuesto declarado (pyme de 10 personas en Bucaramanga)
Usuarios	10 internos + invitados	Ficha del caso
VPN de acceso remoto	Hasta 10 usuarios simultáneos (diseño para 6 portátiles hoy)	Trabajo híbrido y consultores en cliente
VPN sitio a sitio	No requerida	Sin sedes adicionales
Servicios publicados	2 (demo y staging, solo 443)	Supuesto 2 del cap. 2
Zonas / VLAN	7 (10, 20, 25, 30, 50, 90, 99)	Cap. 3.2
Funciones	IPS, control de aplicaciones, filtrado web, antimalware, inspección SSL/TLS	Guía del parcial y riesgos R-02, R-06
Alta disponibilidad	No (se acepta el riesgo por presupuesto)	Presupuesto Bajo
Exportación de logs	Syslog (CEF deseable) hacia Wazuh	Cap. 3.3

7.2 Dimensionamiento

Rendimiento mínimo con seguridad activa = 300 Mbps × 1,3 = **390 Mbps → mínimo 400 Mbps** de throughput de prevención de amenazas (no el de firewall básico, que siempre es varias veces mayor).

Opción	Modelo	Prevención de amenazas	IPsec VPN	¿Cumple?	Fuente
A	Fortinet FortiGate 50G	1,1 Gbps (mezcla empresarial)	4,5 Gbps	Sí, con amplio margen	SHI
B	Palo Alto Networks PA-410	0,6–0,7 Gbps (HTTP / appmix)	0,93 Gbps	Sí	CDW
C	Ruijie RG-WALL 1600-Z3200-S	Por confirmar en el datasheet (firewall base 1 Gbps, ampliable a 3 Gbps por licencia)	Por confirmar	Probable; confirmar	Ficha del producto

Las cifras vienen de páginas de distribuidores que citan la hoja de datos del fabricante. Para el informe final hay que adjuntar el datasheet oficial de cada modelo en `05-ngfw/` y corregir cualquier diferencia. Respaldo si un fabricante no responde: Sophos XGS de entrada o WatchGuard Firebox de la serie T.

7.3 Matriz comparativa ponderada (preliminar)

Calificación 1–5 por criterio. Las notas técnicas son preliminares, con base en las hojas de datos; **costo y soporte local se califican solo cuando lleguen las cotizaciones**.

Criterio	Peso	A: FortiGate 50G	B: PA-410	C: Ruijie Z3200-S
Rendimiento con seguridad activa frente a 400 Mbps	20 %	5	4	3
Funciones NGFW (IPS, apps, web, AV, SSL)	15 %	5	5	4
VPN y conectividad	10 %	5	4	4
Gestión y facilidad de operación	10 %	4	3	4
Integración y logs (syslog/CEF, API)	10 %	5	5	3
Costo total a 3 años	15 %	[cotización]	[cotización]	[cotización]
Soporte y disponibilidad en Colombia	10 %	[confirmar partner]	[confirmar partner]	[confirmar partner]
Escalabilidad y HA	5 %	4	4	4
Capacitación y comunidad	5 %	5	4	2
Puntaje parcial (75 % evaluado, máx. 3,75)		**3,60**	**3,15**	**2,60**

Cálculo: Σ (nota × peso) ÷ 100 sobre los criterios ya evaluados. Por ejemplo, la opción A: (5×20 + 5×15 + 5×10 + 4×10 + 5×10 + 4×5 + 5×5) ÷ 100 = 3,60.

Lectura provisional: técnicamente la FortiGate 50G va adelante; la PA-410 es muy sólida en prevención pero suele costar más en suscripciones, y la Ruijie compite por precio. Con un CAPEX de COP 20 M para todo el SOC, el costo a 3 años puede cambiar el orden: esa es justamente la pregunta que responden las cotizaciones.

El correo de solicitud y el cuadro consolidado de las tres cotizaciones (equipo, suscripciones a 1 y 3 años, soporte, IVA y TCO) están en el **Anexo E**.

7.4 Selección y justificación

[PENDIENTE COTIZACIONES: opción elegida, modelo, TCO a 3 años, relación con el tope de CAPEX y qué se sacrifica si no cabe.]

Sea cual sea el modelo, debe poder enviar a Wazuh tráfico denegado, eventos de IPS y antimalware, filtrado web, accesos VPN y cambios de configuración por syslog.

8. Procesos del SOC N1

El SOC opera con un modelo híbrido: dos personas internas cubren el N1 de 7:00 a 19:00 y se turnan la guardia, y un proveedor externo actúa como N2 por bolsa de horas. Todo pasa por GLPI y cada alerta sigue el mismo flujo de siete pasos.

8.1 Roles

Rol	Persona (ficticia)	Responsabilidades
Analista SOC N1 principal	Felipe Torres (ftorres)	Monitorea, hace triage, documenta en GLPI, contiene lo básico y escala
Analista N1 de respaldo	Paula Vargas (pvargas)	Cubre la tarde y las ausencias; como administradora de TI no cierra tickets de cambios que ella misma ejecutó
Soporte N2	Proveedor externo (cuenta `n2-proveedor`)	Investiga y contiene incidentes confirmados; decide acciones de mayor impacto
Responsable del SOC	Laura Martínez (lmartinez)	Aprueba procesos, severidades, exclusiones y cambios de reglas; reporta KPIs

Rol	Persona (ficticia)	Responsabilidades
Administrador de TI	Paula Vargas	Ejecuta cambios por ticket aprobado (parches, cuentas, restauraciones)
Gerencia	Andrés Gómez (agomez)	Aprueba presupuesto; decide comunicaciones externas y avisos a clientes o a la SIC

8.2 Matriz de severidad

Severidad	Criterio	Ejemplos en C21	Reconocer	Escalar a N2	Notificar
Crítica	Compromiso confirmado de un activo crítico o impacto inmediato	Acceso exitoso a staging tras fuerza bruta con datos de clientes; ransomware en SRV-BKP; exfiltración de una base de cliente	15 min	Inmediato (≤ 15 min)	Responsable del SOC y gerencia por llamada
Alta	Actividad maliciosa probable con impacto significativo	Cambio en `odoo.conf` sin ticket; CVE crítico explotable en SRV-DEMO; cuenta sudo nueva sin solicitud	30 min	≤ 30 min tras confirmar	Responsable del SOC
Media	Sospechoso, impacto limitado	Fuerza bruta bloqueada por active response; USB bloqueado con intento de copia; phishing sin clic	2 h	Según playbook	En el ticket
Baja	Bajo riesgo o con control compensatorio	Escaneo desde Internet bloqueado por el NGFW; CVE medio sin exposición	8 h hábiles	No	En el ticket
Informativa	Auditoría, sin acción	Cambio aprobado en `odoo.conf` dentro de ventana	1 día hábil	No	Ninguna

8.3 Flujo de triage

Paso	Qué hace el N1	Registro en GLPI
1. Recibir	Atiende la alerta de Wazuh, Kaspersky, NGFW o el reporte de un usuario	Abre el ticket con la plantilla "Alerta de seguridad"
2. Registrar	Anota ID de regla, hora, activo, usuario y origen	Campos obligatorios completos
3. Enriquecer	Consulta inventario, historial del activo en GLPI, eventos previos en Wazuh y reputación de la IP o hash (sin subir archivos)	Seguimiento con hallazgos
4. Clasificar	¿Es legítimo? Si sí: falso positivo o benigno. Si no o hay duda: asigna severidad	Categoría y prioridad
5. Contener	Solo las acciones permitidas del playbook	Acción y hora
6. Escalar o cerrar	Si cumple el criterio, escala con la plantilla 8.5; si no, cierra con causa y evidencia	Asignación a SOC N2 o solución
7. Aprender	Propone ajuste de regla o política	Ticket de Cambio

8.4 Acciones permitidas y prohibidas para el N1

Permitidas (si el playbook lo indica)	Prohibidas (N2 o cambio aprobado)
Poner un archivo en cuarentena desde el EDR	Borrar o alterar evidencias
Aislar un equipo (Alta o Crítica) y avisar a N2	Apagar o restaurar SRV-DEMO, STG, DB o BKP
Bloquear temporalmente una IP externa en el NGFW	Eliminar o modificar cuentas privilegiadas
Pedir a TI el bloqueo de una cuenta no privilegiada	Cambiar políticas, exclusiones o reglas sin ticket de cambio
Pedir al usuario que no toque un correo o equipo	Forense, ingeniería inversa o acciones contra el origen del ataque

8.5 Plantilla de escalamiento a N2

Campo	Contenido
Ticket y hora	N.º GLPI; hora de la alerta y del escalamiento (America/Bogota)

Campo	Contenido
Severidad y SLA	Severidad y tiempo restante para reconocer
Resumen	Qué pasó en 2–3 líneas
Activos y usuarios	Equipos, cuentas y servicios; si hay datos de un cliente involucrados, el nombre del proyecto (no los datos)
Línea de tiempo	Hora – evento, en orden
Evidencias	IDs de alerta, hashes, IP, capturas
Acciones del N1	Qué se hizo y a qué hora
Hipótesis	Qué se cree que pasa y con qué confianza
Solicitud a N2	Decisión o acción que se necesita
Contacto	Rol, canal y disponibilidad del N1

8.6 Playbooks adaptados al caso

Los 9 playbooks se publican en la base de conocimiento de GLPI y están completos, con la estructura del Anexo F, al final de este informe. Los PB-01, PB-03 y PB-09 cubren los tres escenarios del caso y usan las reglas reales del laboratorio.

ID	Playbook	Disparador en C21	Severidad inicial	Escala a N2 cuando
PB-01	Fuerza bruta SSH / login de Odoo	Wazuh 5712, **100212**	Media si el bloqueo aplicó; Alta en staging o demo; Crítica si hubo login exitoso (5715)	Login exitoso, usuario `root` / `odoo`, origen interno o datos reales en staging
PB-02	Malware detectado por el EDR	Kaspersky (eventos en Wazuh)	Media si se bloqueó; Alta si se ejecutó o está en un servidor	Ejecución confirmada, ransomware o más de un equipo
PB-03	Cambio en archivos críticos / configuración del ERP	Wazuh 550/554, **100210/100211**	Informativa con ticket de cambio; Alta sin ticket	Sin ticket en DEMO/STG o cambio de credenciales en `odoo.conf`
PB-04	Inicio de sesión fuera de horario o anómalo	Wazuh (horario), VPN del NGFW	Baja/Media para consultor; Alta para cuenta administrativa	Cuenta privilegiada o el usuario no lo reconoce
PB-05	Uso de USB no autorizado	Kaspersky (control de dispositivos)	Baja si se bloqueó; Alta si hay base de cliente	Copia de datos de clientes o reincidencia
PB-06	Phishing reportado	Usuario → GLPI	Baja sin clic; Alta si entregó credenciales	Credenciales entregadas o adjunto ejecutado
PB-07	Escaneo de puertos	IPS del NGFW / Wazuh	Baja desde Internet; Media interno	Origen interno o seguido de explotación
PB-08	Cuenta privilegiada nueva	Wazuh (FIM sobre `/etc/sudoers`, grupo sudo)	Alta; Crítica en DB o BKP	Siempre que no haya solicitud aprobada
PB-09	Vulnerabilidad crítica	Wazuh Vulnerability Detection	Media; Alta si está expuesto en la DMZ	Explotación activa o servidor expuesto sin parche

8.7 Turnos y guardias

Franja	Cobertura	Responsable	Alcance
L–V 7:00–15:00	Monitoreo activo	Felipe Torres	Todas las severidades
L–V 11:00–19:00	Monitoreo activo (4 h de traslape)	Paula Vargas	Todas las severidades
Noches 19:00–7:00	Guardia por notificación	Rotación semanal Felipe / Paula	Crítica y alta; respuesta en 30 min; N2 externo para críticas
Fines de semana y festivos	Guardia + revisión del tablero a las 9:00 y 17:00	Rotación semanal	Crítica y alta; pendientes

Los recargos nocturnos y dominicales de la guardia se liquidan según la normativa laboral vigente (verificar). Relevo de turno a las 15:00 con checklist: alertas abiertas, tickets y vencimientos de SLA, incidentes en curso, cambios programados y falsos positivos conocidos; queda en un ticket diario "Bitácora de turno" en GLPI.

Matriz de contactos: N1 de turno → Responsable del SOC (lmartinez) → N2 externo → Gerencia (agomez). Canal principal: llamada; respaldo: correo y mensajería corporativa.

8.8 SLAs del SOC

Severidad	Reconocer	Triage completo	Escalar a N2	Contener o resolver	Cobertura
Crítica	15 min	30 min	≤ 15 min tras confirmar	4 h	24×7
Alta	30 min	1 h	≤ 30 min tras confirmar	8 h	Laboral + guardia
Media	2 h	4 h	Según playbook	24 h	Laboral
Baja	8 h hábiles	1 día hábil	No aplica	72 h	Laboral
Informativa	1 día hábil	No aplica	No aplica	5 días hábiles	Laboral

Meta: ≥ 90 % de tickets dentro del SLA. Los tiempos son los mismos configurados en GLPI (cap. 6.5).

8.9 KPIs

KPI	Fórmula	Fuente	Meta
MTTD	Promedio (hora de la alerta − hora de inicio del evento)	Wazuh / Kaspersky	≤ 15 min en crítica y alta
MTTA	Promedio (primera acción del analista − hora de la alerta)	GLPI	Dentro del SLA en ≥ 90 %
MTTR	Promedio (contención o cierre − hora de la alerta)	GLPI	Según severidad
Tasa de falsos positivos	FP cerrados ÷ total cerrados × 100	GLPI	< 30 % al tercer mes
Cumplimiento de SLA	Tickets en SLA ÷ total × 100	GLPI	≥ 90 %
Cobertura de agentes	Agentes activos ÷ equipos del inventario × 100	Wazuh + Kaspersky vs. GLPI	≥ 98 %
CVE críticos abiertos > 30 días	Conteo	Wazuh	0 en la DMZ
Demos con datos reales	Tickets "Nueva demo" sin marca de datos enmascarados	GLPI	0

El último KPI es propio del caso: mide directamente el riesgo particular de ERP Pyme Fácil.

8.10 Tickets

La guía pide al menos 6 tickets, uno por tipo de alerta, con 3 originados en alertas reales del laboratorio. **Las 3 alertas reales ya están generadas** (FIM, fuerza bruta SSH y vulnerabilidad crítica); el informe de incidente de la vulnerabilidad es el Anexo D. El detalle completo de los 8 tickets está en `tickets.csv`, listo para importar a GLPI; los simulados se marcan con `[SIMULADO]` en el título.

N.°	Playbook	Origen	Tipo	Datos de la alerta
T-01	PB-03	FIM: `/etc/odoo/odoo.conf` modificado en `ub-c21pn-01`	Real	Reglas 550 + 100210, 21/10/2026 03:33:07 UTC
T-02	PB-01	Fuerza bruta SSH desde 192.168.56.1 contra `ub-c21pn-01`	Real	Reglas 5712 + 100212, 03:47:10 UTC; DROP y desbloqueo 03:50:12
T-03	PB-09	Vulnerabilidad crítica CVE-2026-72422 en `ub-c21pn-01`	Real	242 críticas; falso positivo justificado (Anexo D)

N.°	Playbook	Origen	Tipo	Datos de la alerta
T-04	PB-02	EICAR en `wc-c21pn-01`	Simulado	Pendiente de Kaspersky
T-05	PB-08	Usuario agregado al grupo `sudo` en `ub-c21pn-01`	Simulado	—
T-06	PB-05	USB no autorizado en `wc-c21pn-01`	Simulado	Pendiente de Kaspersky
T-07	PB-06	Correo de phishing reportado por una consultora	Simulado	—
T-08	PB-04	Acceso VPN de madrugada	Simulado	—

El archivo `tickets.csv` acompaña a este informe y trae, por ticket, el triage completo, la clasificación y la decisión. Cuando la instancia de GLPI esté en línea se importa y se adjunta la exportación y las capturas de la mesa de servicio.

9. Presupuesto, cronograma y RACI

El SOC debe caber en CAPEX ≤ COP 20 M y OPEX ≤ COP 1,5 M/mes. El software de base (Wazuh y GLPI) no cuesta licencia, así que el dinero se va en el NGFW con sus suscripciones, las licencias de Kaspersky, un servidor para el SIEM y el VPS de GLPI. Todos los valores salen de cotizaciones o calculadoras con fecha. **[PENDIENTE COTIZACIONES]**

9.1 Presupuesto

Concepto	Tipo	Fuente del valor	Cant.	Valor unitario (COP)	Total (COP)	Frecuencia
Servidor físico para Wazuh + KSC (8 vCPU, 32 GB RAM, 500 GB SSD)	CAPEX	Cotización de proveedor de hardware	1	[ ]	[ ]	Única
Wazuh (licencia)	—	Código abierto	1	0	0	—
Kaspersky Next EDR Foundations (20 equipos)	OPEX	Cotización del distribuidor	20	[ ]	[ ]	Anual
NGFW: equipo	CAPEX	Cotización del cap. 7	1	[ ]	[ ]	Única
NGFW: suscripciones y soporte	OPEX	Cotización del cap. 7	1	[ ]	[ ]	Anual
VPS de GLPI (2 vCPU, 4 GB, 40 GB + instantáneas)	OPEX	Calculadora del proveedor de nube	1	[ ]	[ ]	Mensual
GLPI (licencia)	—	Código abierto	1	0	0	—
Dominio y certificado	OPEX	Registrador; Let's Encrypt (gratuito)	1	[ ]	[ ]	Anual
Switch administrable 16 puertos con VLAN	CAPEX	Cotización (solo si el actual no soporta 802.1Q)	1	[ ]	[ ]	Única
Implementación (horas de consultoría)	CAPEX	Supuesto declarado: horas × tarifa	[h]	[ ]	[ ]	Única
Capacitación del N1 y del personal	CAPEX	Cotización o supuesto	1	[ ]	[ ]	Única
Soporte N2 externo (bolsa de horas)	OPEX	Cotización de un MSSP	[h/mes]	[ ]	[ ]	Mensual
Contingencia 10 % sobre CAPEX	—	Cálculo	—	—	[ ]	—

Indicador	Fórmula	Resultado
CAPEX total	Suma de costos únicos + contingencia	[ ]
OPEX anual	Recurrentes anualizados (mensuales × 12)	[ ]
OPEX mensual	OPEX anual ÷ 12	[ ]
TCO a 3 años	CAPEX + 3 × OPEX anual	[ ]
Costo mensual por empleado	OPEX mensual ÷ 10	[ ]

Indicador	Fórmula	Resultado
Costo mensual por equipo	OPEX mensual ÷ 20	[ ]
¿Cabe en el tope?	CAPEX ≤ 20 M y OPEX mensual ≤ 1,5 M	[ ]

Supuestos a declarar cuando lleguen los valores: TRM certificada por la Superintendencia Financiera (con fecha), IVA del 19 %, horas y tarifa de implementación.

Si no cabe en el tope, el escenario básico sacrifica en este orden: (1) Kaspersky solo en los 10 equipos más críticos (servidores y portátiles) y Wazuh en los 20; (2) N2 externo por evento en vez de bolsa mensual; (3) servidor del SIEM reacondicionado en lugar de nuevo. Lo que no se sacrifica es el NGFW con IPS frente a la DMZ, porque cubre el riesgo R-02.

9.2 Cronograma de implementación (8 semanas)

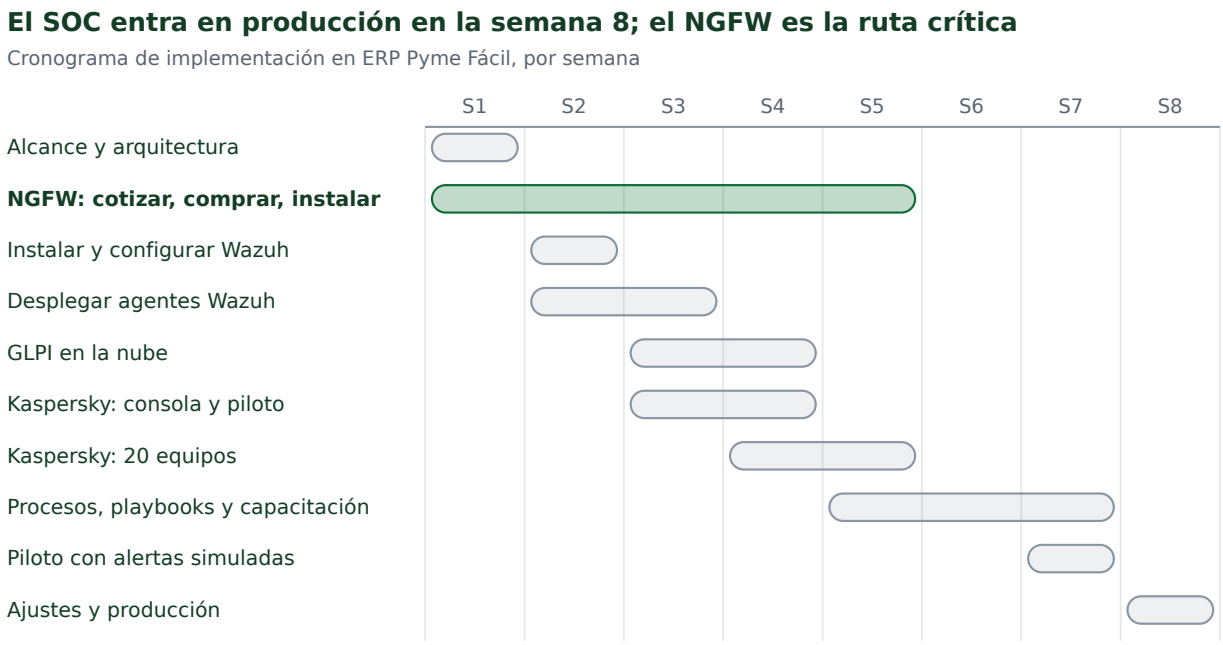


Diagrama 2. *Cronograma de implementación de 8 semanas; la compra del NGFW es la ruta crítica.*

El NGFW es la ruta crítica: cotizar, aprobar, comprar y recibir el equipo puede tomar varias semanas, por eso arranca en la semana 1 aunque se instale en la 5. Mientras tanto, la DMZ se protege con el firewall actual y SSH restringido.

9.3 Matriz RACI

R = ejecuta · A = aprueba (uno solo) · C = consultado · I = informado.

Actividad	Gerencia (agomez)	Resp. SOC / líder del proyecto (lmartinez)	Analista N1 (ftorres)	Admin. de TI (pvargas)	Proveedor NGFW	Proveedor EDR
Aprobar alcance y autorización	A	R	I	C	—	—
Diseñar arquitectura y segmentación	I	A	C	R	C	—
Instalar y configurar Wazuh	I	A	C	R	—	—
Desplegar Kaspersky	I	A	C	R	—	C

Actividad	Gerencia (agomez)	Resp. SOC / líder del proyecto (lmartinez)	Analista N1 (ftorres)	Admin. de TI (pvargas)	Proveedor NGFW	Proveedor EDR
Desplegar y configurar GLPI	I	A	C	R	—	—
Comprar e instalar el NGFW	A	R	I	C	R	—
Definir procesos y playbooks	I	A	R	C	—	—
Capacitar al personal	I	A	R	C	C	C
Política de datos enmascarados en demos	A	R	I	C	—	—
Piloto y puesta en producción	A	R	R	C	I	I

10. Conclusiones

Resultados. Con tres VM en un anfitrión de 16 GB se demostró el ciclo completo de los tres escenarios del caso. Un cambio en la configuración del ERP se detecta en segundos y sube a nivel 10 por la regla 100210. Una fuerza bruta SSH contra el servidor del ERP se detecta, sube a nivel 12 por la regla 100212, se bloquea sola y se libera a los 182 segundos. Y ante 242 alertas críticas de vulnerabilidad, el N1 no parcheó a ciegas: hizo el triage del CVE-2026-72422 y lo clasificó como falso positivo con evidencia del fabricante. Son, en ese orden, los riesgos que más pesan en ERP Pyme Fácil después de la exposición de datos de clientes.

Lo que no funcionó a la primera. Las reglas que filtraban por `syscheck.path` no coincidían, y se resolvió con `<match>`. El instalador de Ubuntu dejó 23 GB de 50, lo que obligó a ampliar el volumen LVM. El espejo de Colombia rechazaba conexiones. El bloque de reglas quedó duplicado en `local_rules.xml` (ya corregido). La respuesta activa bloqueó al propio anfitrión porque no había lista blanca. El manager tarda 1–2 minutos en levantar tras encender la VM. Cada uno quedó documentado con su corrección.

Limitaciones. El laboratorio usa un agente Linux y uno Windows, no los 20 equipos; el resto se cubre con el plan de despliegue masivo. La VM cliente es Windows 10, no Windows 11. Las VM están en UTC y se homologan a America/Bogota. Kaspersky, GLPI y las cotizaciones no se habían ejecutado al cierre de esta versión. La memoria del servidor (5 GB) está por debajo de la recomendada (8 GB).

Riesgos residuales. Datos reales de clientes en demos (R-01): el SOC lo vigila, pero la medida de fondo es la política de datos enmascarados. Un solo analista principal: depende de la guardia y del N2 externo. Sin alta disponibilidad del SIEM ni del NGFW, aceptado por presupuesto.

Trabajo futuro. Integración automática Wazuh → GLPI para abrir tickets desde las alertas de nivel ≥ 10, decoder para el log de inicio de sesión de Odoo, MFA en la VPN y datos sintéticos en todas las demos.

Referencias

Formato APA 7. Las fuentes con enlace fueron consultadas entre el 20 y el 21 de octubre de 2026.

- Congreso de Colombia. (2009). *Ley 1273 de 2009, por medio de la cual se modifica el Código Penal, se crea un nuevo bien jurídico tutelado denominado "de la protección de la información y de los datos"*.
- Congreso de Colombia. (2012). *Ley Estatutaria 1581 de 2012, por la cual se dictan disposiciones generales para la protección de datos personales*.
- International Organization for Standardization. (2022). *ISO/IEC 27001:2022 Information security, cybersecurity and privacy protection — Information security management systems — Requirements*.
- National Institute of Standards and Technology. (2024). *The NIST Cybersecurity Framework (CSF) 2.0* (NIST CSWP 29). https://doi.org/10.6028/NIST.CSWP.29
- Jaimes Rincón, J. B. (2026). *Parcial práctico: Implementación de un SOC Nivel 1 para una pyme de TI de 10 empleados y 20 equipos* [Guía de clase]. Unidades Tecnológicas de Santander.
- Wazuh Inc. (2026). *Wazuh documentation: Quickstart* (versión 4.14). https://documentation.wazuh.com/current/quickstart.html
- Wazuh Inc. (2026). *File integrity monitoring* (versión 4.14). https://documentation.wazuh.com/current/user-manual/capabilities/file-integrity/index.html
- Wazuh Inc. (2026). *Active Response* (versión 4.14). https://documentation.wazuh.com/current/user-manual/capabilities/active-response/index.html
- Wazuh Inc. (2026). *Rules syntax* (versión 4.14). https://documentation.wazuh.com/current/user-manual/ruleset/ruleset-xml-syntax/rules.html
- Wazuh Inc. (2026). *Vulnerability detection* (versión 4.14). https://documentation.wazuh.com/current/user-manual/capabilities/vulnerability-detection/index.html
- Wazuh Inc. (2026). *Installing Wazuh agents on Windows endpoints* (versión 4.14). https://documentation.wazuh.com/current/installation-guide/wazuh-agent/wazuh-agent-package-windows.html
- MITRE. (s. f.). *T1110 Brute Force* y *T1565.001 Stored Data Manipulation*. MITRE ATT&CK. https://attack.mitre.org/techniques/T1110/
- Kaspersky. (s. f.). *Funciones clave de Kaspersky Next*. https://support.kaspersky.com/help/NextPro/1.0/es-ES/144165.htm
- Kaspersky. (s. f.). *About event export — Kaspersky Security Center Cloud Console*. https://support.kaspersky.com/KSC/CloudConsole/en-US/151330.htm
- Kaspersky. (2025). *Configuring Kaspersky Security Center for export of events to a SIEM system*. https://support.kaspersky.com/ksc14/216090
- SHI International. (s. f.). *Fortinet FortiGate 50G* [Ficha de producto]. https://www.shi.com/product/49371474/Fortinet-FortiGate-50G
- CDW Canada. (s. f.). *Palo Alto Networks PA-410* [Ficha de producto]. https://cdw.ca/product/palo-alto-networks-pa-410-security-appliance-lab-unit/6817357?pfm=srh
- Nale. (s. f.). *Ruijie RG-WALL 1600-Z3200-S* [Ficha de producto]. https://subang.nale.co.id/?p=81969
- GLPI Project. (2026). *GLPI installation documentation*. [agregar URL de la versión instalada]
- Center for Internet Security. (s. f.). *CIS Benchmarks: Ubuntu Linux 24.04 LTS y Microsoft Windows 11*. [agregar URL]

Pendiente de reemplazo: las tres fichas de distribuidores por los datasheets oficiales de Fortinet, Palo Alto Networks y Ruijie.

Anexos

La base de conocimiento completa (14 artículos) está en el repositorio, carpeta `06-procesos/`.

Anexo A — Inventario de activos

C/I/D de 1 a 3; la criticidad es el valor máximo. W = Wazuh, K = Kaspersky, G = GLPI Agent.

ID	Hostname	Tipo	SO	Función	Propietario	VLAN	C/I/D	Crit.	W/K/G
A-01	PC-C21PN-01	Estación	Windows 11 Pro	Líder de consultoría	Líder de consultoría	10	2/2/2	2	Sí/Sí/Sí
A-02	PC-C21PN-02	Estación	Windows 11 Pro	Consultoría contable	Líder de consultoría	10	3/2/2	3	Sí/Sí/Sí
A-03	PC-C21PN-03	Estación	Windows 11 Pro	Consultoría de nómina	Líder de consultoría	10	3/2/2	3	Sí/Sí/Sí
A-04	PC-C21PN-04	Estación	Windows 11 Pro	Consultoría de inventarios	Líder de consultoría	10	2/2/2	2	Sí/Sí/Sí
A-05	PC-C21PN-05	Estación	Windows 11 Pro	Consultoría de facturación electrónica	Líder de consultoría	10	2/2/2	2	Sí/Sí/Sí
A-06	PC-C21PN-06	Estación	Windows 11 Pro	Pruebas funcionales y capacitación	Líder de consultoría	10	2/2/1	2	Sí/Sí/Sí
A-07	PC-C21PN-07	Estación	Windows 11 Pro	Administración de TI	Gerente de operaciones	10	3/3/2	3	Sí/Sí/Sí
A-08	PC-C21PN-08	Estación	Windows 11 Pro	Soporte y analista SOC N1	Gerente de operaciones	10	3/2/2	3	Sí/Sí/Sí
A-09	LT-C21PN-01	Portátil	Windows 11 Pro	Consultor en cliente	Líder de consultoría	10 / VPN	3/2/2	3	Sí/Sí/Sí
A-10	LT-C21PN-02	Portátil	Windows 11 Pro	Consultor en cliente	Líder de consultoría	10 / VPN	3/2/2	3	Sí/Sí/Sí
A-11	LT-C21PN-03	Portátil	Windows 11 Pro	Consultor en cliente	Líder de consultoría	10 / VPN	3/2/2	3	Sí/Sí/Sí
A-12	LT-C21PN-04	Portátil	Windows 11 Pro	Consultor en cliente	Líder de consultoría	10 / VPN	3/2/2	3	Sí/Sí/Sí
A-13	MAC-C21PN-01	Portátil	macOS	Gerencia general	Gerente general	10 / VPN	3/2/2	3	Sí/Sí/Sí
A-14	MAC-C21PN-02	Portátil	macOS	Gerencia de operaciones	Gerente de operaciones	10 / VPN	3/2/2	3	Sí/Sí/Sí
A-15	DEV-C21PN-01	Estación	Ubuntu Desktop 24.04	Desarrollo de módulos Odoo	Admin. de TI	10	3/3/2	3	Sí/Sí/Sí
A-16	DEV-C21PN-02	Estación	Ubuntu Desktop 24.04	Desarrollo e integraciones	Admin. de TI	10	3/3/2	3	Sí/Sí/Sí
A-17	SRV-C21PN-DEMO	Servidor	Ubuntu Server 24.04	ERP de demostración (Odoo + Nginx), expuesto	Admin. de TI	25 DMZ	3/3/2	3	Sí/Sí/Sí
A-18	SRV-C21PN-DB	Servidor	Ubuntu Server 24.04	PostgreSQL de demo y staging	Admin. de TI	20	3/3/3	3	Sí/Sí/Sí
A-19	SRV-C21PN-STG	Servidor	Ubuntu Server 24.04	Staging de proyectos de clientes	Admin. de TI	25 DMZ	3/3/2	3	Sí/Sí/Sí
A-20	SRV-C21PN-BKP	Servidor	Ubuntu Server 24.04	Respaldos (bases y archivos)	Admin. de TI	20	3/3/3	3	Sí/Sí/Sí

Equipos de red y servicios (fuera de los 20):

ID	Activo	Tipo	Propietario	Ubicación	Crit.	Monitoreo
N-01	NGFW-C21PN	Firewall perimetral (a cotizar)	Admin. de TI	Oficina, VLAN 99	3	Syslog → Wazuh
N-02	SW-C21PN-01	Switch administrable 16 puertos	Admin. de TI	Oficina, VLAN 99	2	Syslog → Wazuh (opcional)
N-03	AP-C21PN-01/02	Puntos de acceso (corporativo e invitados)	Admin. de TI	Oficina, VLAN 99	2	Registro en GLPI
S-01	VPS GLPI	Servidor en la nube (soporte.erppymefacil.example)	Gerente de operaciones	Nube pública	2	Agente Wazuh por VPN (opcional)
S-02	Correo corporativo	SaaS	Gerente general	Nube del proveedor	2	Responsabilidad del proveedor
S-03	Dominio y DNS	Servicio	Gerente general	Registrador	2	Registro en GLPI

Anexo B — Matriz de riesgos

Nivel = P × I (1–4 Bajo · 5–9 Medio · 10–16 Alto · 17–25 Crítico). Ordenada de mayor a menor.

ID	Riesgo	Activo	P	I	Nivel	Control del SOC	Resp.	Fase
R-01	Fuga de datos reales de clientes cargados en demo o staging sin enmascarar (Ley 1581)	SRV-DEMO, SRV-STG, SRV-DB	4	5	20 Crítico	Política de datos enmascarados, FIM sobre carpetas de importación, PB-09 y PB-03, alertas de exfiltración en NGFW	Gerente de operaciones	0, 2, 6
R-02	Explotación de un CVE crítico en el servidor de demostración expuesto	SRV-DEMO	4	4	16 Alto	Detección de vulnerabilidades de Wazuh, IPS del NGFW, PB-09	Admin. de TI	2, 5
R-03	Acceso no autorizado por fuerza bruta SSH a staging	SRV-STG	4	4	16 Alto	Regla de fuerza bruta + active response; SSH solo por VPN; PB-01	Analista N1	2, 5
R-04	Ransomware en estaciones que alcance el servidor de respaldos	PC, LT, SRV-BKP	3	5	15 Alto	EDR con prevención de comportamiento, respaldo inmutable/fuera de línea, PB-02	Admin. de TI	3, 4
R-05	Cambio no autorizado en `odoo.conf` (contraseña maestra, conexión a la BD)	SRV-DEMO, SRV-STG	3	4	12 Alto	FIM en tiempo real con `report_changes`, regla personalizada, PB-03	Analista N1	2
R-06	Robo de credenciales de VPN por phishing a consultores	LT-01 a 04, MAC	3	4	12 Alto	Regla de inicio de sesión anómalo, control web del EDR, PB-04 y PB-06, MFA en VPN	Analista N1	3, 6
R-07	Pérdida o robo de un portátil con bases de clientes	LT-01 a 04	3	4	12 Alto	Inventario GLPI, cifrado de disco, aislamiento remoto desde el EDR	Admin. de TI	3, 4
R-08	Agentes de portátiles desconectados sin que nadie lo note	LT, MAC	4	3	12 Alto	Regla de agente desconectado, KPI de cobertura ≥ 98 %	Analista N1	2, 6
R-09	Alertas críticas sin atender por tener un solo analista	Todos	3	4	12 Alto	Turnos, guardia por notificación, SLA y OLA con N2	Responsable del SOC	6
R-10	Respaldos que fallan o nunca se han restaurado	SRV-BKP, VPS GLPI	3	4	12 Alto	Tareas de respaldo, prueba trimestral de restauración, FIM sobre scripts	Admin. de TI	4
R-11	Copia de bases de clientes a USB	PC, LT	3	3	9 Medio	Control de dispositivos del EDR, PB-05	Analista N1	3
R-12	Instancia GLPI expuesta con cuentas por defecto o sin parches	VPS GLPI	2	4	8 Medio	Hardening, HTTPS, eliminación de cuentas por defecto	Admin. de TI	4

ID	Riesgo	Activo	P	I	Nivel	Control del SOC	Resp.	Fase
R-13	Relojes desincronizados que impiden correlacionar eventos	Todos	3	2	6 Medio	NTP único, zona America/Bogota	Admin. de TI	1

R-01 es el único riesgo crítico y sale directamente del riesgo particular del caso. El SOC no lo elimina por sí solo: la medida de fondo es una política de "cero datos reales en demo" con datos enmascarados, y el SOC vigila que se cumpla.

Anexo H — Carta de autorización y reglas de compromiso

CARTA DE AUTORIZACIÓN Y REGLAS DE COMPROMISO — Implementación de un SOC Nivel 1 (laboratorio académico)

1. **Partes.** El Cliente: ERP Pyme Fácil S.A.S. (empresa ficticia), representada para efectos del ejercicio por Julian Barney Jaimes Rincon en calidad de representante legal ficticio. Los Consultores: Juan Pérez y Juan Niño, estudiantes de las Unidades Tecnológicas de Santander.
2. **Objeto.** Autorizar a los Consultores a diseñar e implementar, en un laboratorio aislado, un SOC Nivel 1 para el Cliente: instalación y configuración de Wazuh (SIEM), Kaspersky (EDR), GLPI (tickets e inventario) y cotización de un NGFW.
3. **Alcance.** Activos incluidos: VM `wz-c21pn-01` (192.168.56.10), `ub-c21pn-01` (192.168.56.11), `wc-c21pn-01` (192.168.56.12) y `ks-c21pn-01` (192.168.56.13) en la red host-only 192.168.56.0/24 del equipo anfitrión, y la instancia GLPI en la nube creada para el ejercicio. Activos excluidos: cualquier sistema de terceros, de la UTS, de clientes reales o de Internet.
4. **Actividades autorizadas.** Instalar y configurar herramientas en VM propias; generar eventos de prueba controlados (archivo EICAR, cambios en archivos vigilados, intentos fallidos de SSH e inicio de sesión entre VM propias, USB virtual); consultar fuentes públicas de reputación sin subir archivos.
5. **Actividades prohibidas.** Escaneos, ataques o pruebas de credenciales fuera del alcance; captura de tráfico ajeno; uso de datos personales reales; desactivar controles de equipos ajenos; publicar credenciales, IP públicas reales o evidencias sensibles; escanear la propia instancia en la nube si el proveedor no lo permite.
6. **Ventana de actividades.** Desde el 20/10/2026 hasta [fecha de sustentación].
7. **Confidencialidad.** Los datos del ejercicio son ficticios. Credenciales y evidencias se tratan como información Restringida y no se publican; en documentos se usa el marcador `CAMBIAR_CLAVE`.
8. **Detención y contacto.** Ante un hallazgo real, duda de alcance o impacto inesperado, los Consultores detienen la actividad, no intentan comprobar el hallazgo y avisan al docente por [canal acordado].
9. **Marco legal.** Las partes reconocen la Ley 1273 de 2009 y la Ley 1581 de 2012 y se comprometen a actuar dentro de sus límites.
10. **Firmas.** Cliente: _____ Consultores: _____ / _____ Fecha: ____ / ____ / 2026

Anexo C — Plantilla de ticket de seguridad

La misma plantilla se carga en GLPI como "Alerta de seguridad" (cap. 6.6).

Campo	Contenido
Título	[Origen] [ID de alerta] – resumen corto (los simulados empiezan con [SIMULADO])
Categoría	Seguridad › subcategoría
Origen	Wazuh / Kaspersky / NGFW / Usuario
Elemento asociado	Activo del inventario
Urgencia / impacto / prioridad	Según la matriz de severidad (cap. 8.2)
Fecha y hora de la alerta	America/Bogota
Activo, usuario, IP origen/destino	

Campo	Contenido
Qué ocurrió	2–3 líneas
Enriquecimiento	Reputación, historial del activo, eventos previos
Evidencias	Enlaces, capturas, hash (sin datos de clientes)
Acciones del N1	Acción y hora
Clasificación y decisión	Falso positivo / Benigno / Verdadero positivo · Cerrar / Escalar a N2
Solución, cierre y mejora	Ajuste de regla o política

Anexo D — Informe de incidente: vulnerabilidad crítica en ub-c21pn-01

Escenario 1 del caso. Todas las horas están en UTC (restar 5 h para Bogotá). Este es el ticket T-03 y el informe de incidente que exige la guía.

1. Identificación

Campo	Valor
ID del ticket en GLPI	T-03 (se registra al desplegar GLPI en la Fase 4; el contenido ya está en `tickets.csv`)
Tipo	Incidente de seguridad: alerta de vulnerabilidad crítica
Origen	Wazuh 4.14.9, módulo Vulnerability Detection
Fecha y hora de análisis	21/10/2026, 17:57 a 18:06 UTC
Analistas N1	Juan Pérez y Juan Niño
Estado	Cerrado como falso positivo justificado (clasificación provisional hasta cerrar el seguimiento de la sección 8)

2. Activo afectado: `ub-c21pn-01` · agente Wazuh 001 (4.14.9) · 192.168.56.11 · Ubuntu Server 24.04.5 LTS · representa el servidor del ERP · kernel `6.8.0-147-generic` (paquete `6.8.0-147.147`).

3. Descripción del hallazgo. Wazuh reporta 242 hallazgos de severidad Critical para el agente 001, todos sobre el paquete `linux-image-6.8.0-147-generic` 6.8.0-147.147. El hallazgo analizado en detalle es el CVE-2026-72422: CVSS 9.8 (NVD, CVSS 3.1, vector de red), use-after-free en ksmbd (servidor SMB del kernel), en `conn->preauth_info`, durante el manejo concurrente de SMB2 NEGOTIATE. Publicado el 15/08/2026.

4. Evidencias

N.°	Evidencia	Hora (UTC)	Origen	Figura
E1	Inventario de Vulnerability Detection: 242 críticos, paquete `linux-image-6.8.0-147-generic` 6.8.0-147.147	21/10/2026	Dashboard de Wazuh	cap. 4.6
E2	Paquete instalado (`dpkg -l`) y kernel en ejecución (`uname -r`): 6.8.0-147.147	17:57:15	`linc21pn@ub-c21pn-01`	—
E3	Ubuntu: `linux` en 24.04 LTS noble figura como *Fixed in 6.8.0-147.147*	21/10/2026	ubuntu.com/security/CVE-2026-72422	—
E4	CTI de Wazuh (Canonical): `linux` en Ubuntu 24.04 Noble afectado *hasta 0:6.8.0-147 (excluyendo)*	21/10/2026	cti.wazuh.com	fig. abajo
E5	`dpkg --compare-versions 6.8.0-147.147 lt 6.8.0-147` devuelve falso (fuera del rango)	18:05:56	`linc21pn@ub-c21pn-01`	—
E6	`ksmbd` no cargado (`lsmod`) y sin servicio en 445/139 (`ss`)	17:59:59	`linc21pn@ub-c21pn-01`	—
E7	Ficha del CVE en la CTI de Wazuh: CVSS 9.8, descripción y fecha	21/10/2026	cti.wazuh.com	fig. abajo
E9	CVE-2026-64268: noble 24.04 *Fixed in 6.8.0-147.147*	~18:10	ubuntu.com	fig. abajo

N.°	Evidencia	Hora (UTC)	Origen	Figura
E10	CVE-2026-72399: noble 24.04 *Fixed in 6.8.0-147.147*	~18:10	ubuntu.com	fig. abajo

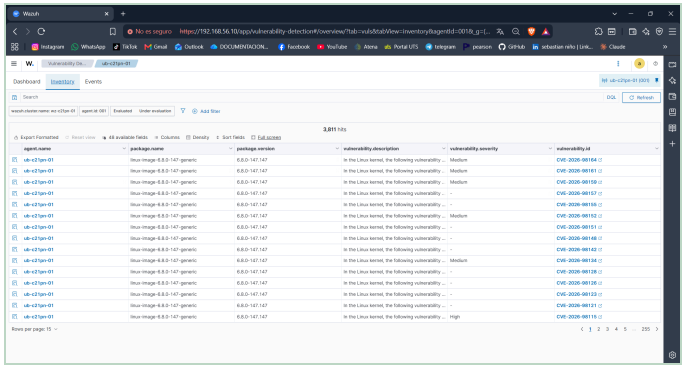


Figura 19. *E1. Inventario de Vulnerability Detection: 3.811 hallazgos, todos sobre el mismo kernel 6.8.0-147.147. (F02_21_vuln_inventario_kernel.png)*

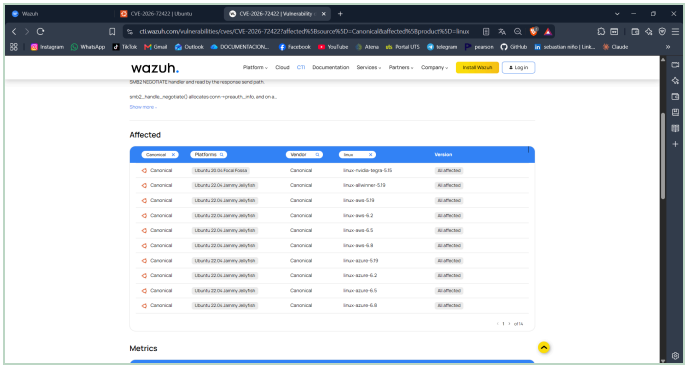


Figura 20. *E4/E7. Ficha del CVE-2026-72422 en la CTI de Wazuh, filtrada por fuente Canonical y producto linux. (F02_22_cti_wazuh_72422.png)*

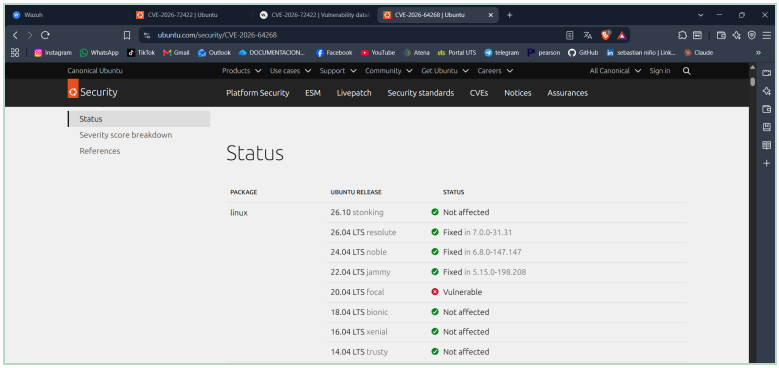


Figura 21. *E9. CVE-2026-64268 en Ubuntu: noble 24.04 LTS figura como Fixed in 6.8.0-147.147. (F02_23_ubuntu_64268.png)*

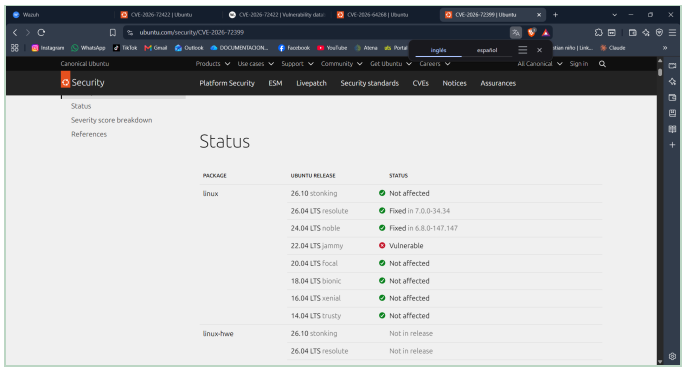


Figura 22. E10. CVE-2026-72399 en Ubuntu: noble 24.04 LTS figura como Fixed in 6.8.0-147.147. (F02_24_ubuntu_72399.png)

5. Análisis (triage)

1. **Versión instalada vs. corregida.** Ubuntu da el CVE-2026-72422 como corregido en `6.8.0-147.147` para noble, y esa es la versión instalada y en ejecución (E2, E3).
2. **Rango afectado según Canonical en Wazuh.** Solo están afectadas las versiones anteriores a `6.8.0-147`; la instalada no lo es, y `dpkg` lo confirma (E4, E5).
3. **Superficie de ataque.** La falla está en ksmbd: el módulo no está cargado y no hay SMB escuchando, así que la superficie no está activa (E6). Refleja el estado actual; no descarta que el módulo se cargue más adelante.
4. **Conclusión.** El activo no está afectado por este CVE. El hallazgo se clasifica como **falso positivo**.
5. **Causa del falso positivo (por confirmar).** Un error de comparación de versiones del escáner, una detección originada en otra fuente de la base (rangos genéricos de NVD u otros fabricantes), o una asociación incorrecta entre el paquete binario `linux-image` y el paquete fuente `linux`.

6. Clasificación. Severidad reportada: Critical (CVSS 9.8). Severidad para el activo: sin riesgo explotable con la evidencia actual. Alcance verificado: CVE-2026-72422, CVE-2026-64268 y CVE-2026-72399 revisados de forma individual (los tres *Fixed in 6.8.0-147.147*); los otros 239 comparten paquete y versión y se evalúan por muestreo.

7. Decisión y acciones. Parcheo: no se requiere (no hay kernel más nuevo disponible y las 8 actualizaciones pendientes no son del kernel). Cierre: falso positivo justificado. Seguimiento: revisar el inventario cuando la base de Wazuh termine de sincronizar y comparar el conteo de críticos. Escalamiento: no aplica; se escalaría a N2 si algún CVE de la muestra figurara como no corregido para la versión instalada.

8. Seguimiento (tareas de N1, no bloquean el cierre). (P1) Capturar el detalle del hallazgo en Wazuh (fecha de detección, condición y fuente del escáner). (P2) Verificar un tercer CVE de otra página del inventario — hechos 2 de 3. (P3) Efecto del estado *Under evaluation* en el conteo de 242. (P4) Confirmar la causa raíz del falso positivo. (P5) Opcional: `modinfo ksmbd`.

9. Lecciones aprendidas. Una alerta crítica de un escáner se contrasta con la fuente del fabricante antes de parchear. Un CVSS alto describe la gravedad en abstracto; el riesgo real depende de si el componente está presente y expuesto. Los conteos masivos se revisan por paquete y por grupo, documentando qué se verificó individualmente y qué por muestreo.

Anexo E — Correo de solicitud de cotización

Asunto: Solicitud de cotización académica – firewall de nueva generación para una pyme (ejercicio universitario)

Buenos días. Somos Juan Pérez y Juan Niño, estudiantes de las Unidades Tecnológicas de Santander (Bucaramanga). Para un ejercicio académico, sin compromiso de compra, estamos diseñando un centro de monitoreo de seguridad para una empresa ficticia de 10 empleados y 20 equipos.

Les agradecemos una cotización de un firewall de nueva generación con estos requisitos: enlace de Internet de 300 Mbps (un proveedor); 10 usuarios; VPN de acceso remoto para hasta 10 usuarios; 2 servidores web publicados en una DMZ; 7 VLAN; funciones de prevención de intrusiones, control de aplicaciones, filtrado web, antimalware e inspección

SSL/TLS; sin alta disponibilidad; exportación de logs por syslog. El modelo que tenemos en mente es [FortiGate 50G / PA-410 / RG-WALL 1600-Z3200-S], pero aceptamos su recomendación.

Por favor incluir: referencia del equipo, suscripciones de seguridad a 1 y a 3 años, soporte y garantía, instalación y capacitación si aplica, valores en COP con IVA discriminado, vigencia de la oferta, tiempo de entrega y datos de contacto.

Muchas gracias por su tiempo.

Juan Pérez y Juan Niño · Unidades Tecnológicas de Santander · [correo] · [teléfono]

Anexo F — Playbooks

Los 9 playbooks del SOC están resumidos en el cap. 8.6 (disparador, severidad y criterio de escalamiento de cada uno) y desarrollados por completo, con la estructura de la plantilla, en el repositorio: carpeta `06-procesos/playbooks/` y publicados en la base de conocimiento de GLPI (KB-1 a KB-9). Los que cubren los tres escenarios del caso son PB-01 (fuerza bruta SSH), PB-03 (cambio en `odoo.conf`) y PB-09 (vulnerabilidad crítica).

Anexo G — Lista de verificación de entrega

Elemento	Estado al 21/10/2026	Cumple
Fase 0. Carta de autorización, inventario (20 equipos) y matriz de riesgos	Completos; falta firma del docente	☐
Fase 1. Diagramas, VLAN, flujos con puertos, dimensionamiento y retención	Completo	☐
Fase 2. Wazuh; agentes Windows y Linux; FIM; SCA; vulnerabilidades; 3+ reglas; active response; dashboards; pruebas	2 agentes activos, FIM, SCA (45 %), vulnerabilidades, 3 reglas y AR con desbloqueo hechos; faltan `wazuh-logtest` y tablero guardado	☐
Fase 3. Kaspersky: edición; consola; agentes; políticas; tareas; exclusiones; eventos en Wazuh; EICAR	Diseño listo; instalación pendiente	☐
Fase 4. GLPI en la nube con HTTPS; configuración; lista de verificación; respaldo y restauración	Diseño listo; instancia pendiente	☐
Fase 5. Tres cotizaciones reales con fecha y contacto; matriz; justificación	Matriz técnica lista; cotizaciones pendientes	☐
Fase 6. Manual del SOC; 9 playbooks; 6+ tickets (3 reales); informe de incidente	Manual, playbooks, Anexo D y 3 alertas reales listos; `tickets.csv` listo; registro en GLPI pendiente	☐
Fase 7. Presupuesto con fuentes; TCO; cronograma; RACI	Cronograma y RACI listos; valores pendientes	☐
Fase 8. Informe PDF; repositorio privado sin secretos; video de 12–15 min	Informe y repositorio listos; video pendiente	☐
Declaración de uso de IA (Anexo I) adjunta	Diligenciada; falta firmar	☐
Revisión final: sin contraseñas, tokens, llaves ni datos reales; enlaces verificados	Revisado en informe y repositorio	☐
Nombres de archivo según el formato	`Parcial_SOC_N1_C21_Perez_Nino.pdf` y `_evidencias.zip`	☐

Anexo I — Declaración de uso de inteligencia artificial

Herramienta	Para qué se usó	Qué se verificó o probó	Qué se modificó o rechazó
Claude (Anthropic)	Estructura del informe y del repositorio; borradores de alcance, inventario, riesgos, arquitectura, diseño de Kaspersky y GLPI, matriz del NGFW, manual del SOC, 9 playbooks y base de conocimiento; explicación de errores de instalación; borrador de las reglas; redacción del análisis del CVE y del Anexo D a partir de las verificaciones hechas en el laboratorio	Las reglas 100210/100211/100212 se probaron y dispararon (cap. 4.7); FIM, SCA, vulnerabilidades y active response con desbloqueo se verificaron con capturas propias; el CVE-2026-72422 se contrastó con Ubuntu, la CTI de Wazuh y comprobaciones locales (`dpkg` , `lsmod` , `ss`); puertos y sintaxis contra la documentación de Wazuh	Se cambió `field syscheck.path` por `match` ; se ajustó el *heap* del indexer a 1 GB y la RAM a 5 GB; se corrigió el hostname `ub-c21np-01` ; se descartaron reglas del borrador no probadas; la clasificación del CVE como falso positivo se decidió con la evidencia, no por sugerencia de la herramienta. [completar con lo que ustedes cambiaron]

☐ Declaramos que lo anterior es completo y que podemos explicar y reproducir todo lo entregado.

Juan Pérez · Firma: ____ · Fecha: _ / _ / 2026

Juan Niño · Firma: ____ · Fecha: _ / _ / 2026

Guion del video (12–15 min)

Tiempo	Qué mostrar
0:00–1:00	Presentación, caso C21, por qué la DMZ con demos es el problema central
1:00–3:00	Diagrama de arquitectura, VLAN y decisión todo en uno
3:00–6:00	Wazuh: agentes activos, FIM sobre `odoo.conf` en vivo, SCA, vulnerabilidades, regla 100210, active response, tablero
6:00–8:00	Kaspersky: consola, políticas y USB bloqueado, EICAR detectado y su llegada a Wazuh
8:00–11:00	GLPI: HTTPS, entidades, perfiles, SLA, plantilla, inventario, KB
11:00–12:30	NGFW: matriz con cotizaciones reales; presupuesto frente al tope
12:30–14:30	Caso T-02 de punta a punta: fuerza bruta SSH → alerta 100212 → bloqueo → ticket → PB-01 → escalamiento o cierre
14:30–15:00	Conclusiones y aprendizajes

Antes de publicar: ver el video completo y tapar contraseñas, correos personales o IP reales. Mantener visible el nombre del caso y la fecha.